



Delegation

Ing. Ondřej Ševeček | GOPAS a.s. |

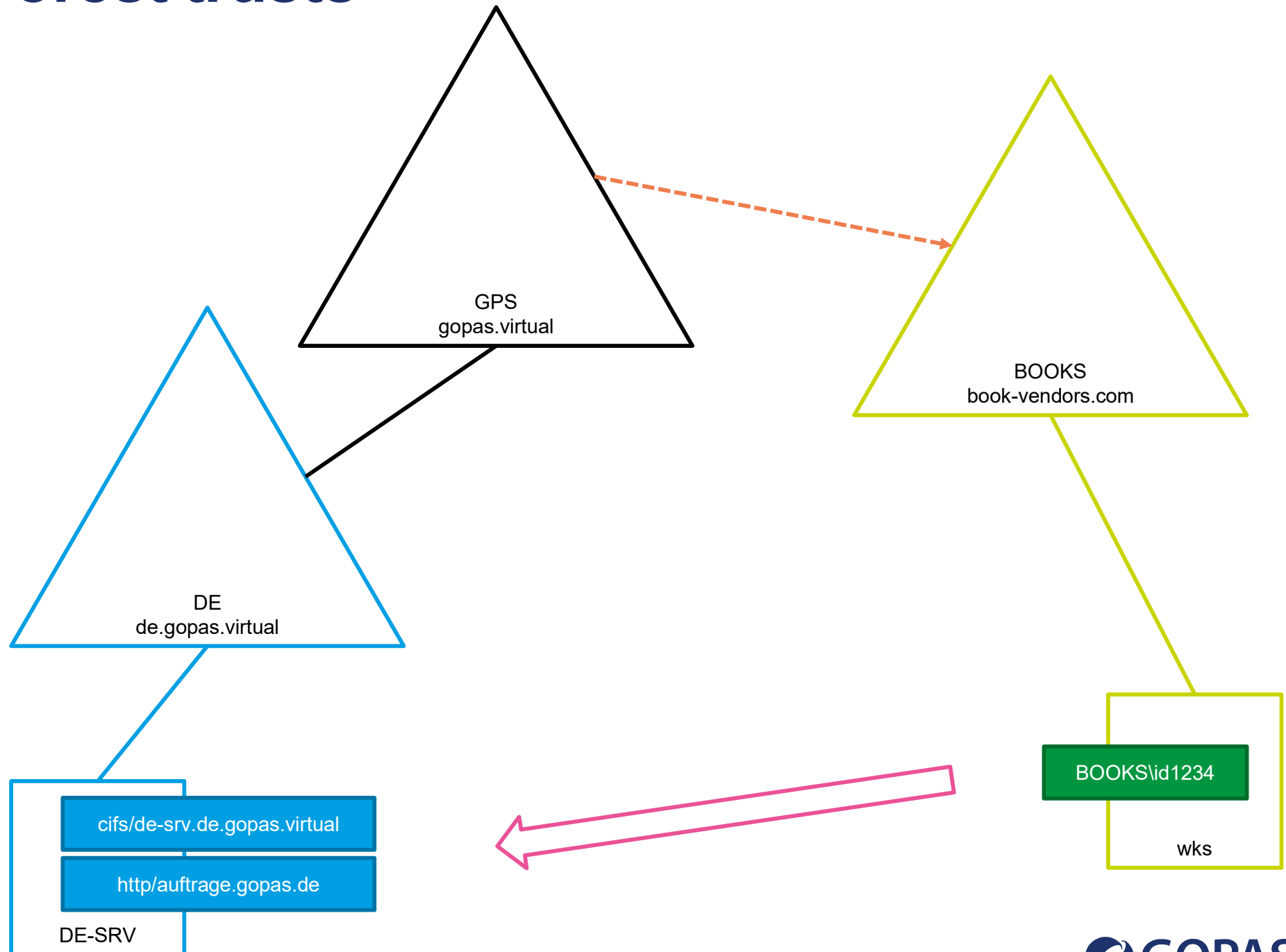
MCSM:Directory2012 | MCM:Directory2008 | MVP:Enterprise Security | CEH: Certified Ethical Hacker | CHFI: Computer Hacking Forensic Investigator | CISA |

ondrej@sevecek.com | www.sevecek.com |

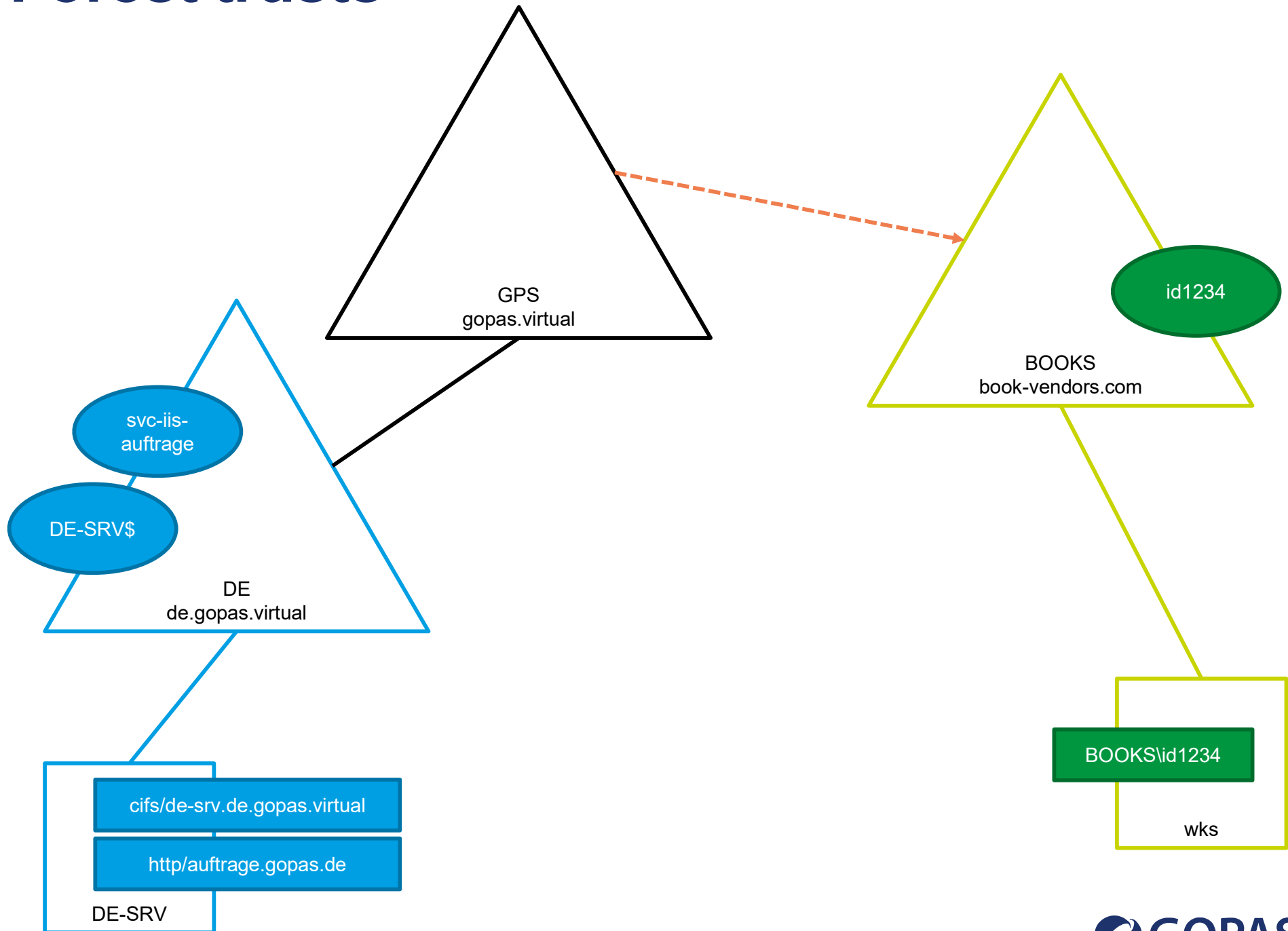
GOPAS: info@gopas.cz | www.gopas.cz | www.facebook.com/P.S.GOPAS

Trusts

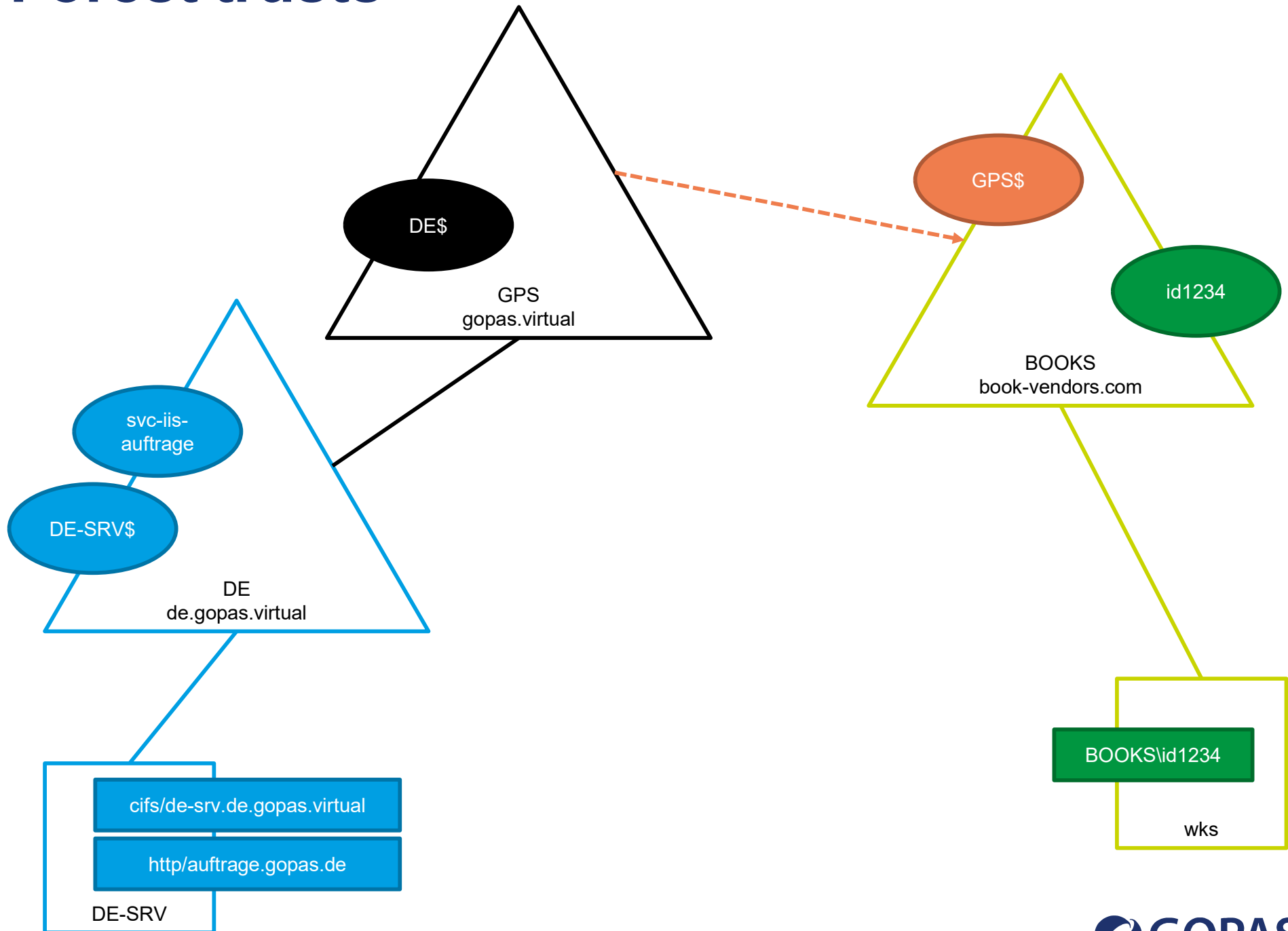
Forest trusts



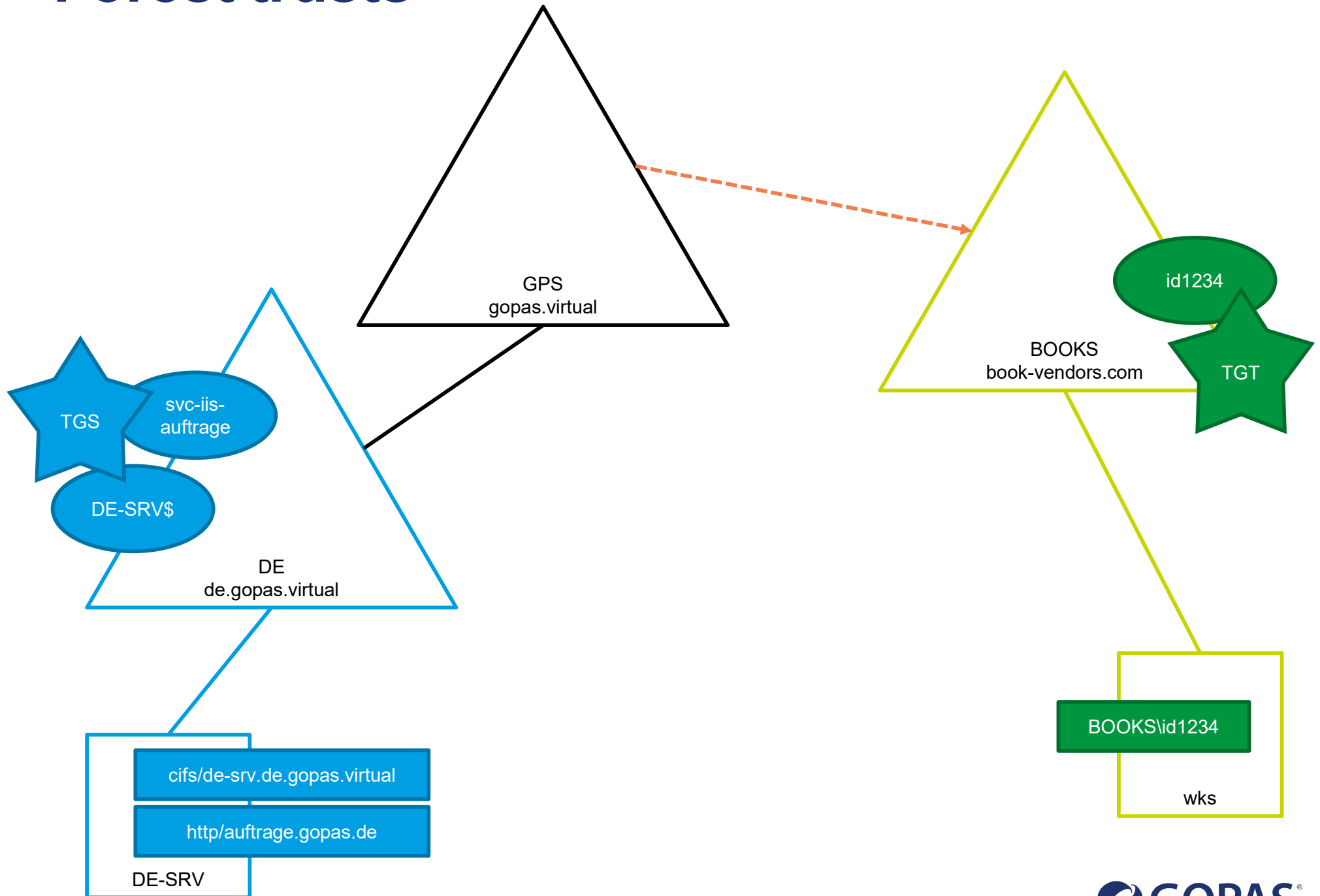
Forest trusts



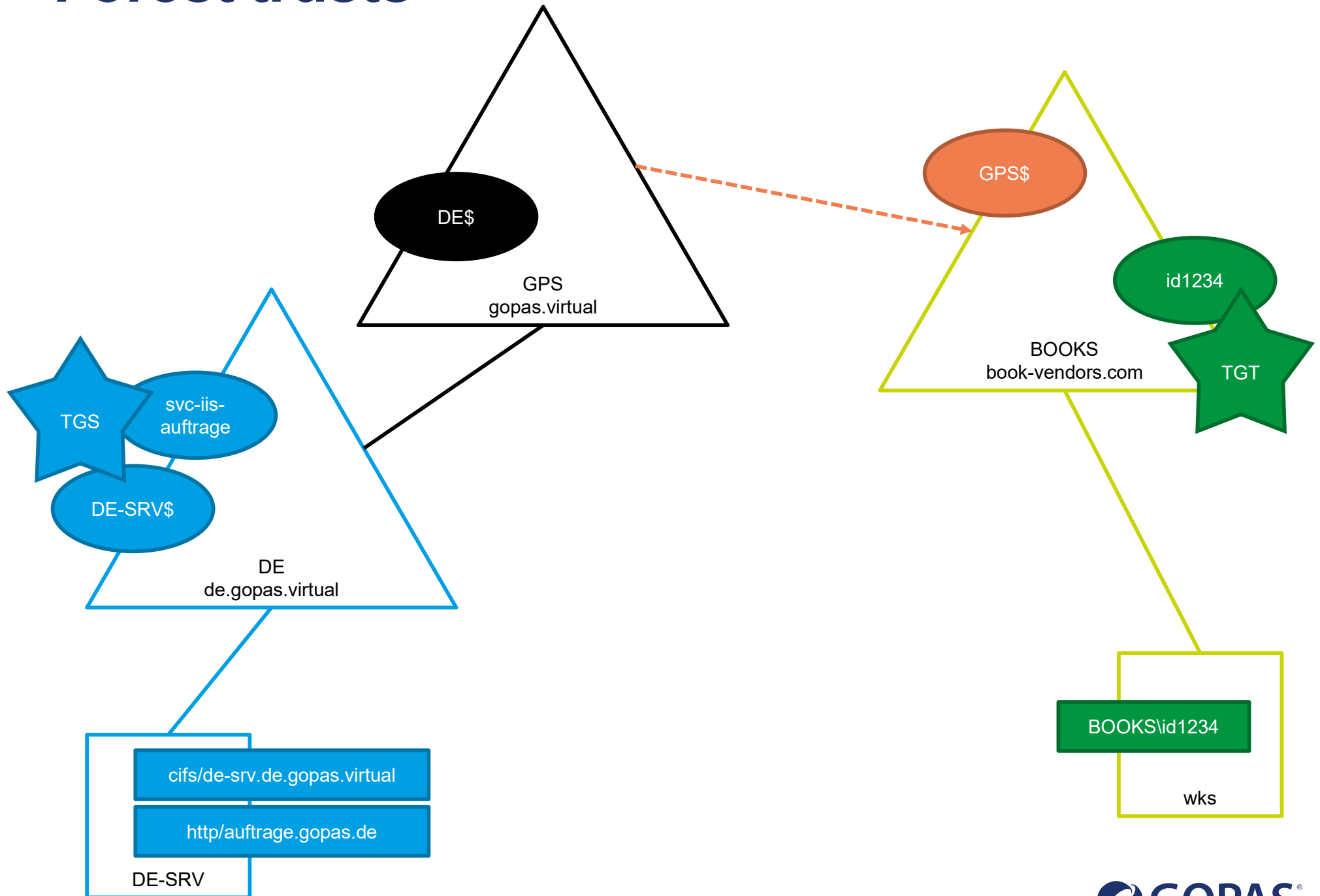
Forest trusts



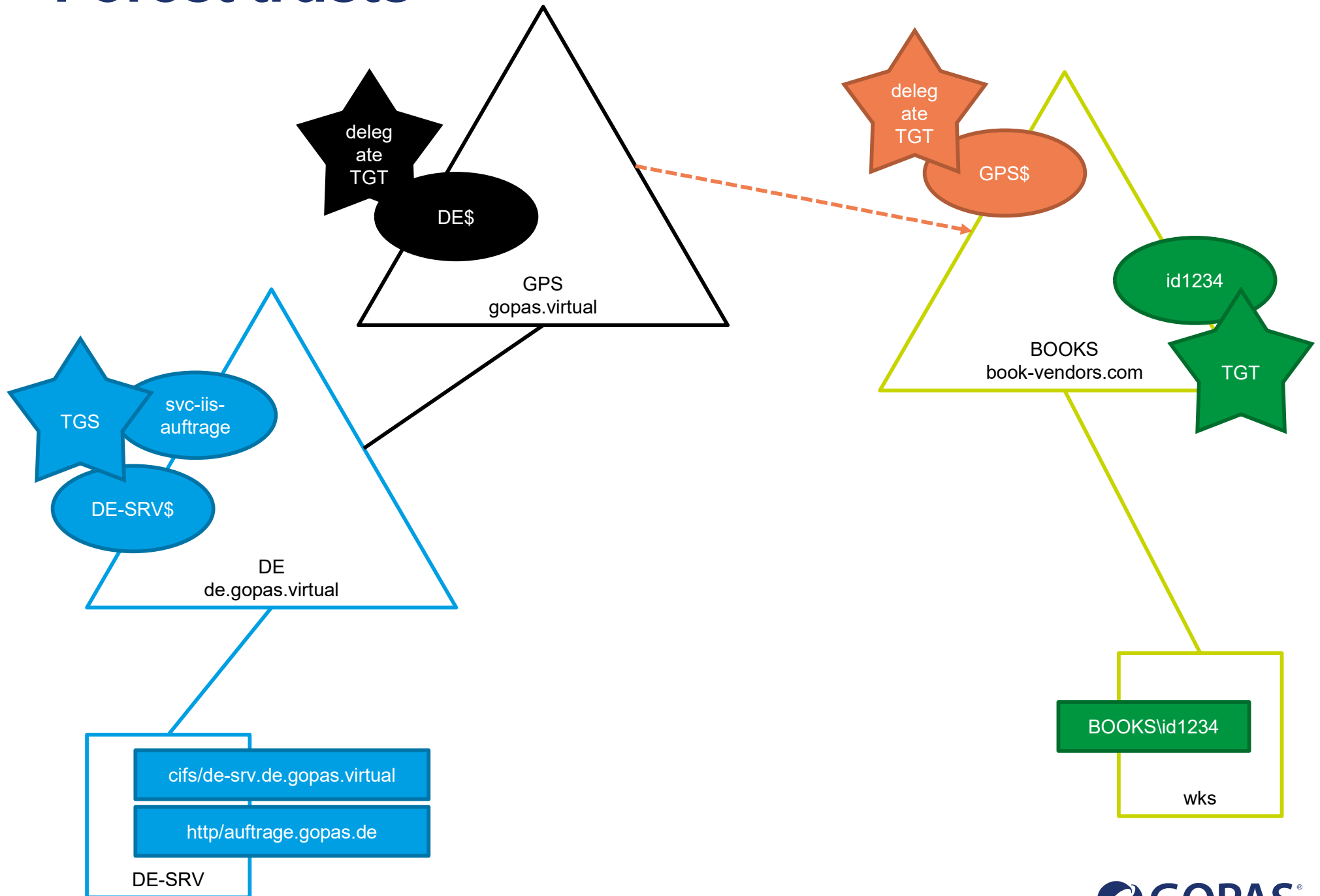
Forest trusts



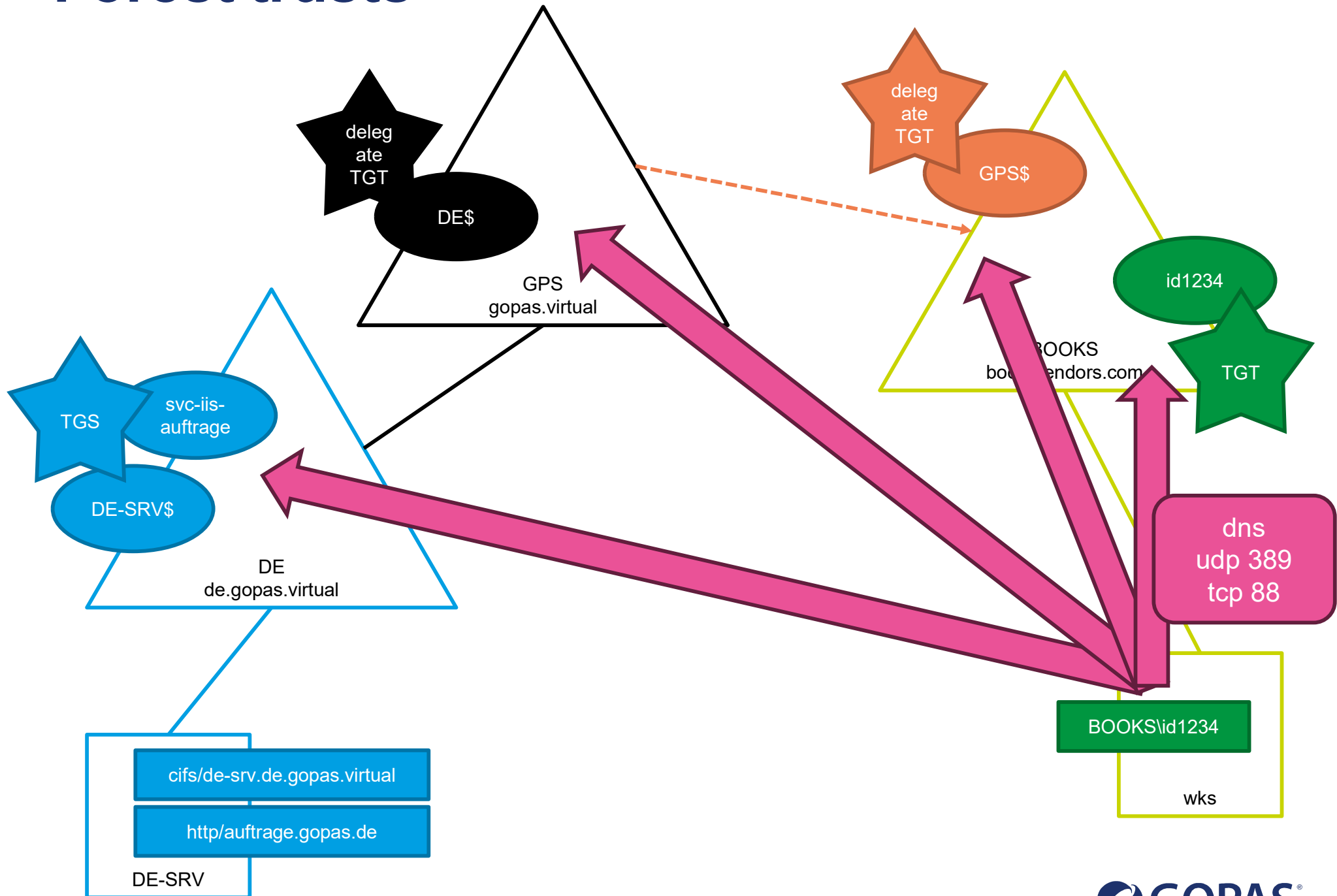
Forest trusts



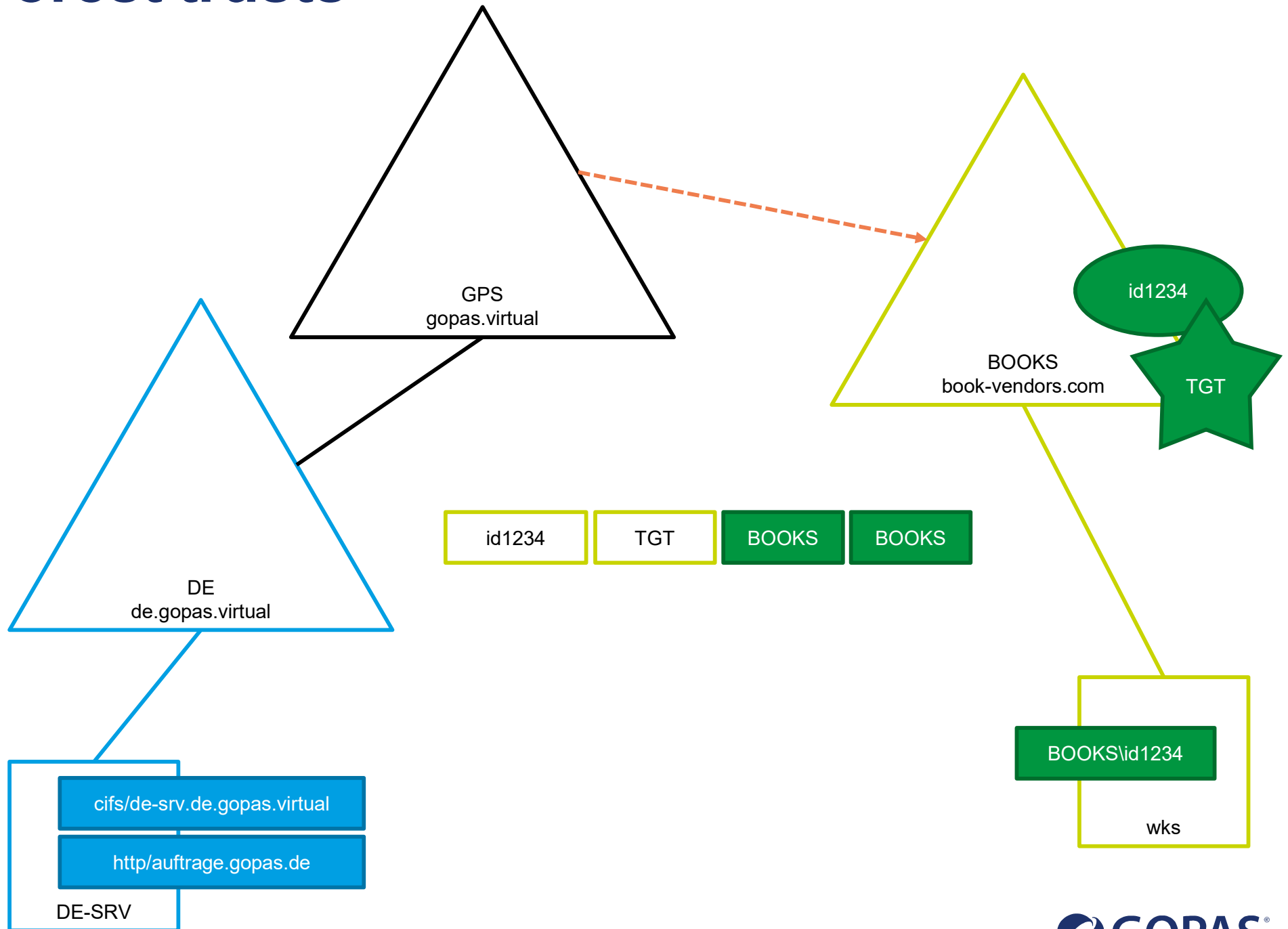
Forest trusts



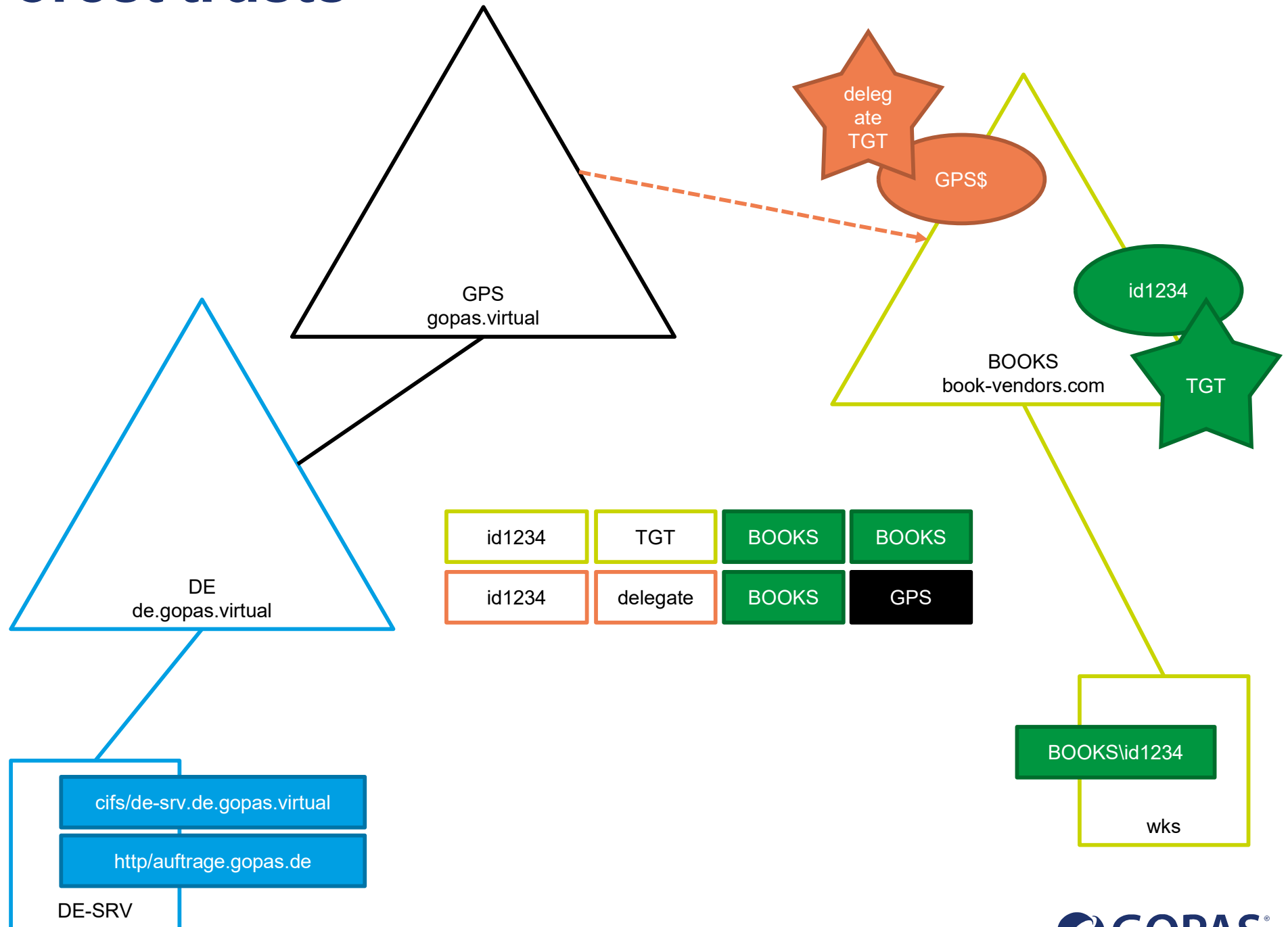
Forest trusts



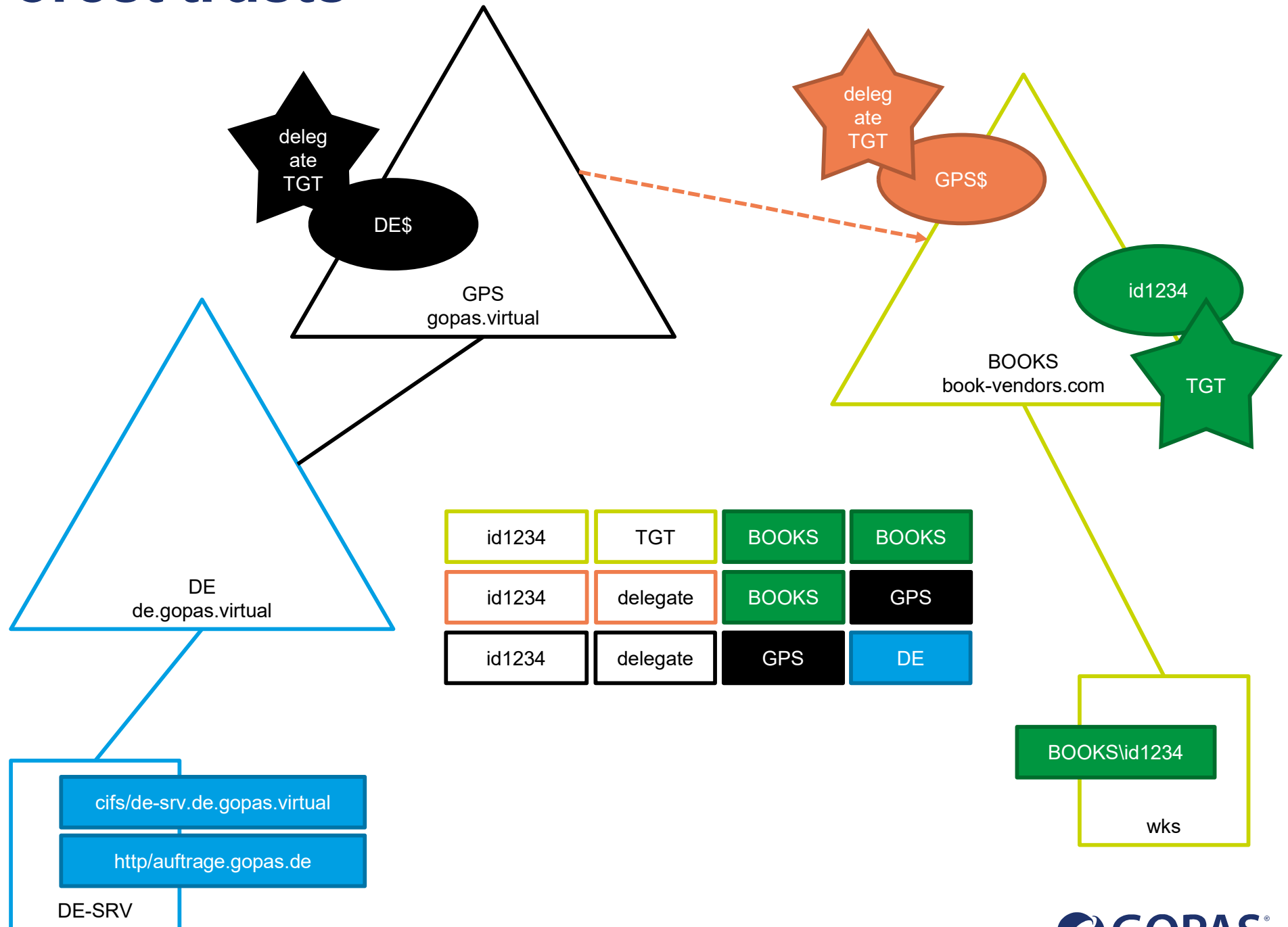
Forest trusts



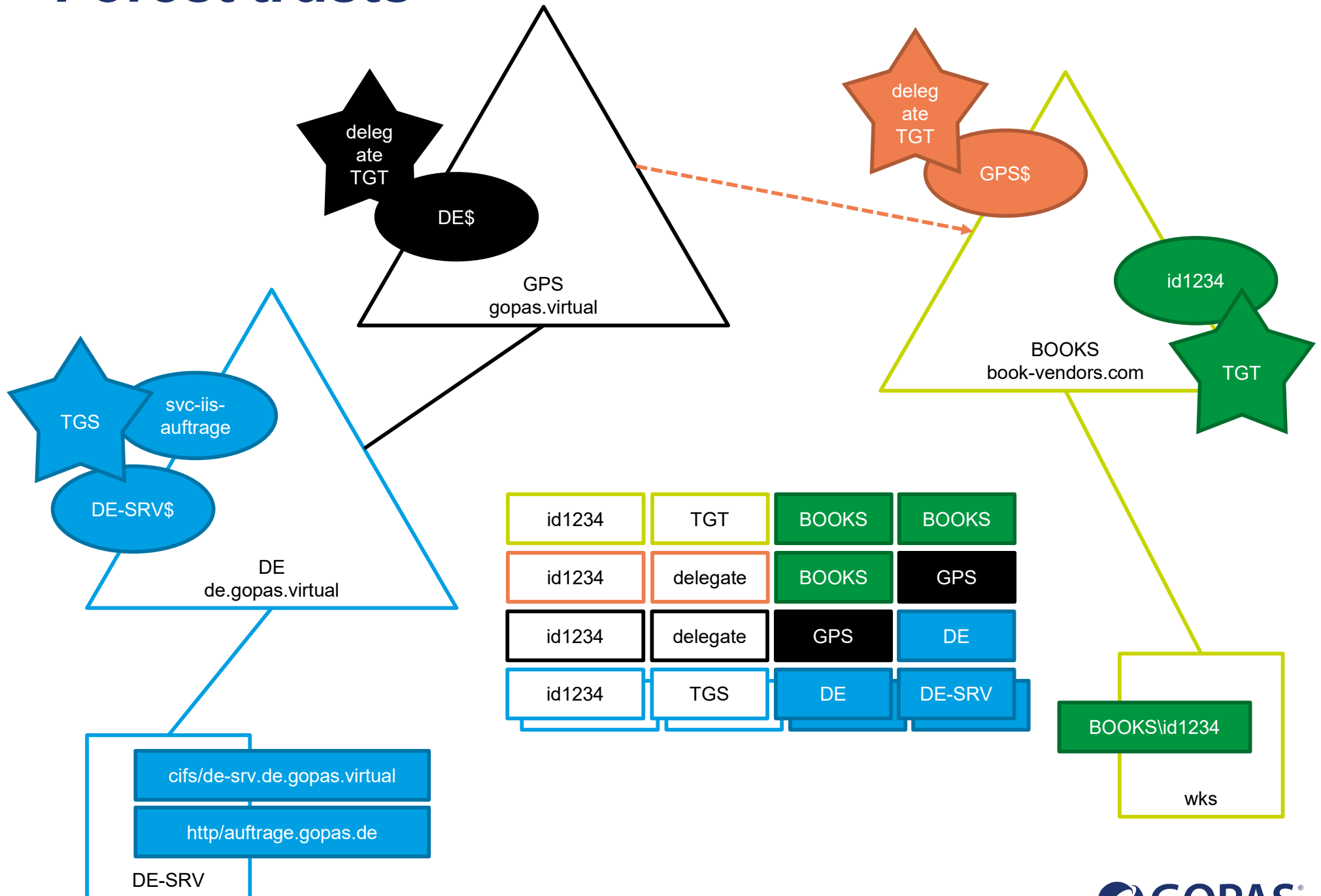
Forest trusts



Forest trusts



Forest trusts



Name suffix routing

Active Directory Domains and Trusts

File Action View Help



Active Directory Domains and Trusts [BOOK!]

book-vendors.com

book-vendors.com Properties

General Trusts Managed By

Domains trusted by this domain (outgoing trusts):

Domain Name	Trust Type	Transitive

Domains that trust this domain (incoming trusts):

Domain Name	Trust Type	Transitive
gopas.virtual	Forest	Yes

New Trust...

OK

Cancel

Apply

gopas.virtual Properties

General Name Suffix Routing

If routing is enabled for a particular name suffix using that suffix are routed to the specified forest.

The specified forest contains multiple name suffixes. If the status of a suffix, select the suffix, and then click the Enable or Disable button.

Name suffixes in the gopas.virtual forest:

Suffix	Routing
*.gopas.cz	Enabled
*.gopas.de	Enabled
*.gopas.virtual	Enabled

Enable

Disable

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/DE.GOPAS.VIRTUAL @ GOPAS.VIRTUAL
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called: GPS-DC1.gopas.virtual

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/GOPAS.VIRTUAL @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: BOOKS-DC.book-vendors.com

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/BOOK-VENDORS.COM @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0x1 -> PRIMARY
Kdc Called: BOOKS-DC.book-vendors.com

Client: ID1234 @ BOOK-VENDORS.COM
Server: cifs/de-srv.de.gopas.virtual @ DE.GOPAS.VIRTUAL
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/DE.GOPAS.VIRTUAL @ GOPAS.VIRTUAL
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called: GPS-DC1.gopas.virtual

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/GOPAS.VIRTUAL @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: BOOKS-DC.book-vendors.com

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/BOOK-VENDORS.COM @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0x1 -> PRIMARY
Kdc Called: BOOKS-DC.book-vendors.com

Client: ID1234 @ BOOK-VENDORS.COM
Server: cifs/de-srv.de.gopas.virtual @ DE.GOPAS.VIRTUAL
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/DE.GOPAS.VIRTUAL @ GOPAS.VIRTUAL
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0
Kdc Called: GPS-DC1.gopas.virtual

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/GOPAS.VIRTUAL @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: BOOKS-DC.book-vendors.com

Client: ID1234 @ BOOK-VENDORS.COM
Server: krbtgt/BOOK-VENDORS.COM @ BOOK-VENDORS.COM
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)

Client: ID1234 @ BOOK-VENDORS.COM
Server: cifs/de-srv.de.gopas.virtual @ DE.GOPAS.VIRTUAL
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_canonicalize
Start Time: 11/25/2022 14:51:48 (local)
End Time: 11/26/2022 0:51:48 (local)
Renew Time: 12/2/2022 14:51:48 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: DE-DC.DE.gopas.virtual

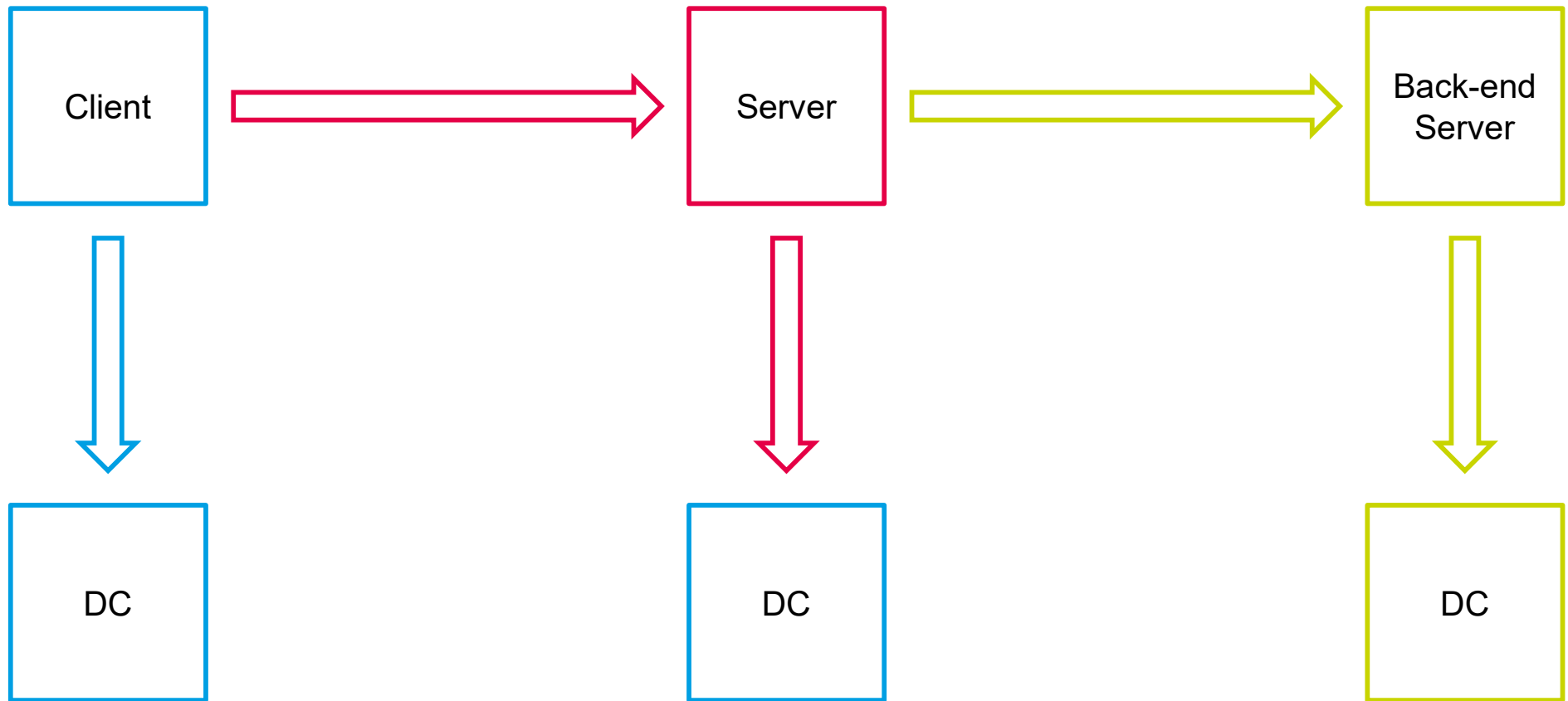
anonicalize

Trust TGT/TGS requests

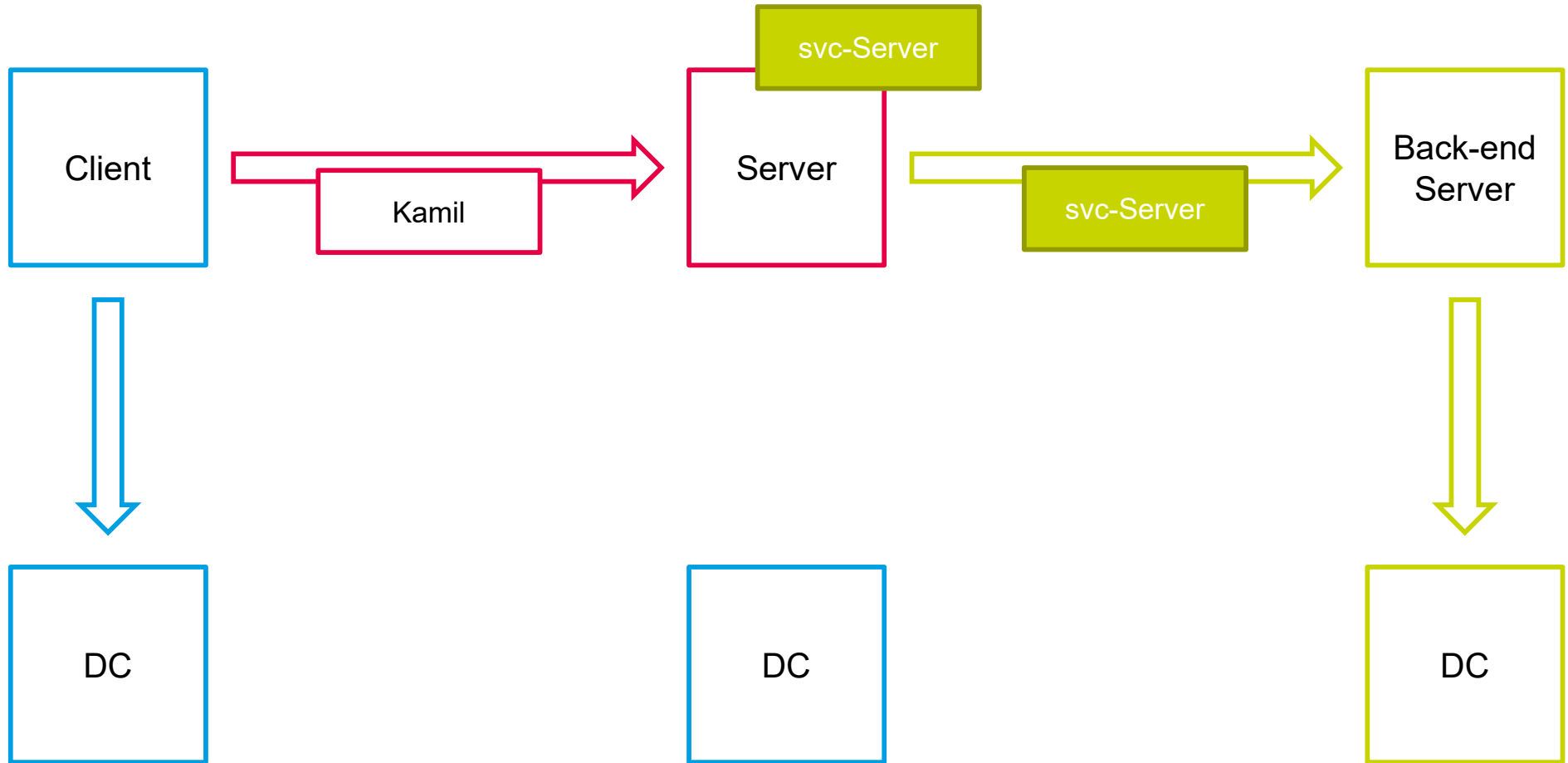
Source	Destination	Protocol Name	Description
10.10.0.102	10.10.0.15	KerberosV5	KerberosV5:AS Request Cname: ID1234 Realm: BOOK-VENDORS.COM Sname: krbtgt/BOOK-VENDORS.COM
10.10.0.15	10.10.0.102	KerberosV5	KerberosV5:KRB_ERROR - KDC_ERR_PREAUTH_REQUIRED (25)
10.10.0.102	10.10.0.15	KerberosV5	KerberosV5:AS Request Cname: ID1234 Realm: BOOK-VENDORS.COM Sname: krbtgt/BOOK-VENDORS.COM
10.10.0.15	10.10.0.102	KerberosV5	KerberosV5:AS Response Ticket[Realm: BOOK-VENDORS.COM, Sname: krbtgt/BOOK-VENDORS.COM]
10.10.0.102	10.10.0.15	KerberosV5	KerberosV5:TGS Request Realm: BOOK-VENDORS.COM Sname: cifs/de-srv.de.gopas.virtual
10.10.0.15	10.10.0.102	KerberosV5	KerberosV5:TGS Response Cname: ID1234
10.10.0.102	gps-dc1.gopas.virtual	KerberosV5	KerberosV5:TGS Request Realm: GOPAS.VIRTUAL Sname: cifs/de-srv.de.gopas.virtual
gps-dc1.gopas.virtual	10.10.0.102	KerberosV5	KerberosV5:TGS Response Cname: ID1234
10.10.0.102	de-dc.de.gopas.virtual	KerberosV5	KerberosV5:TGS Request Realm: DE.GOPAS.VIRTUAL Sname: cifs/de-srv.de.gopas.virtual
de-dc.de.gopas.virtual	10.10.0.102	KerberosV5	KerberosV5:TGS Response Cname: ID1234

Multi-hop

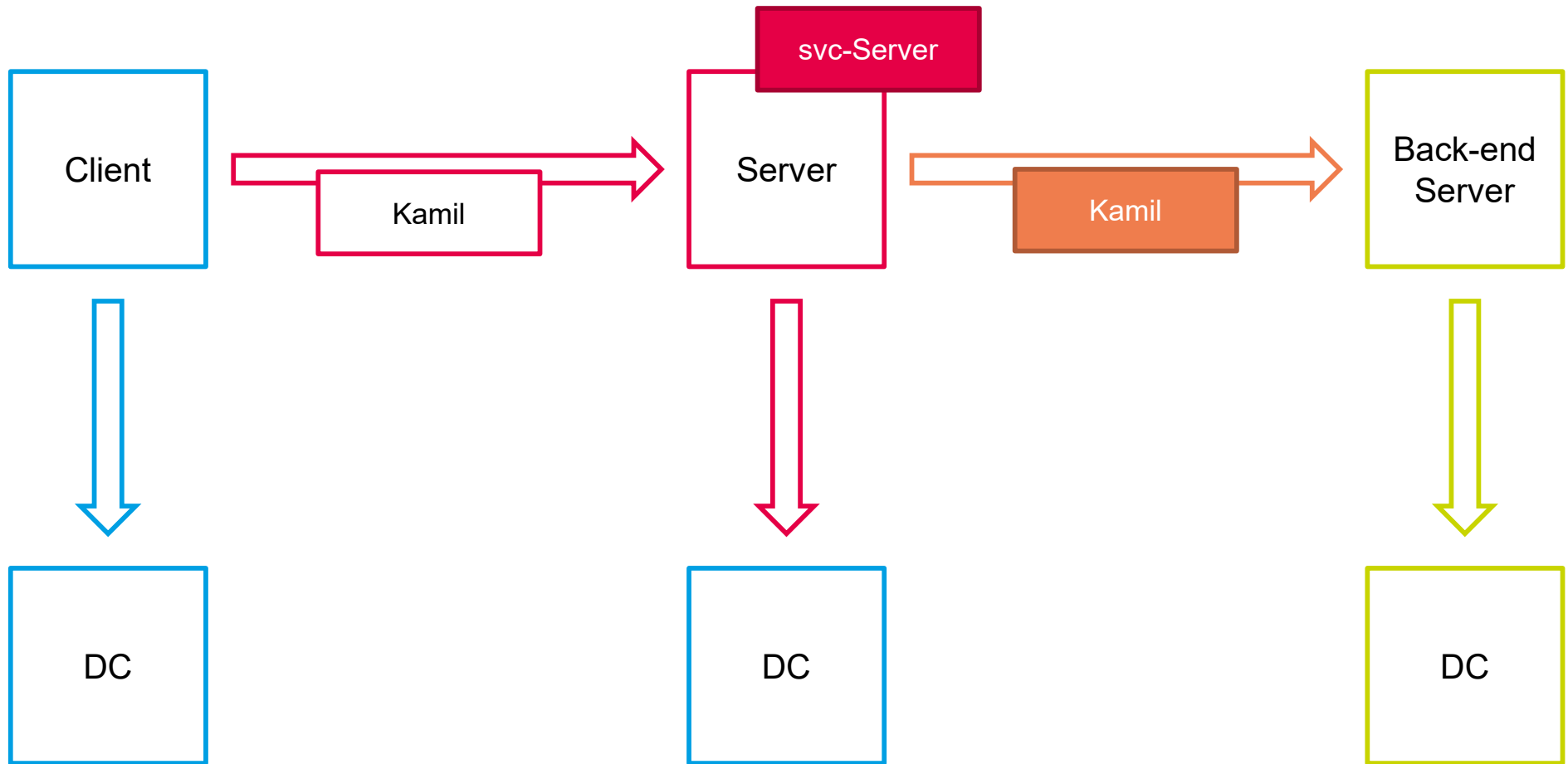
Delegation (double-hop)



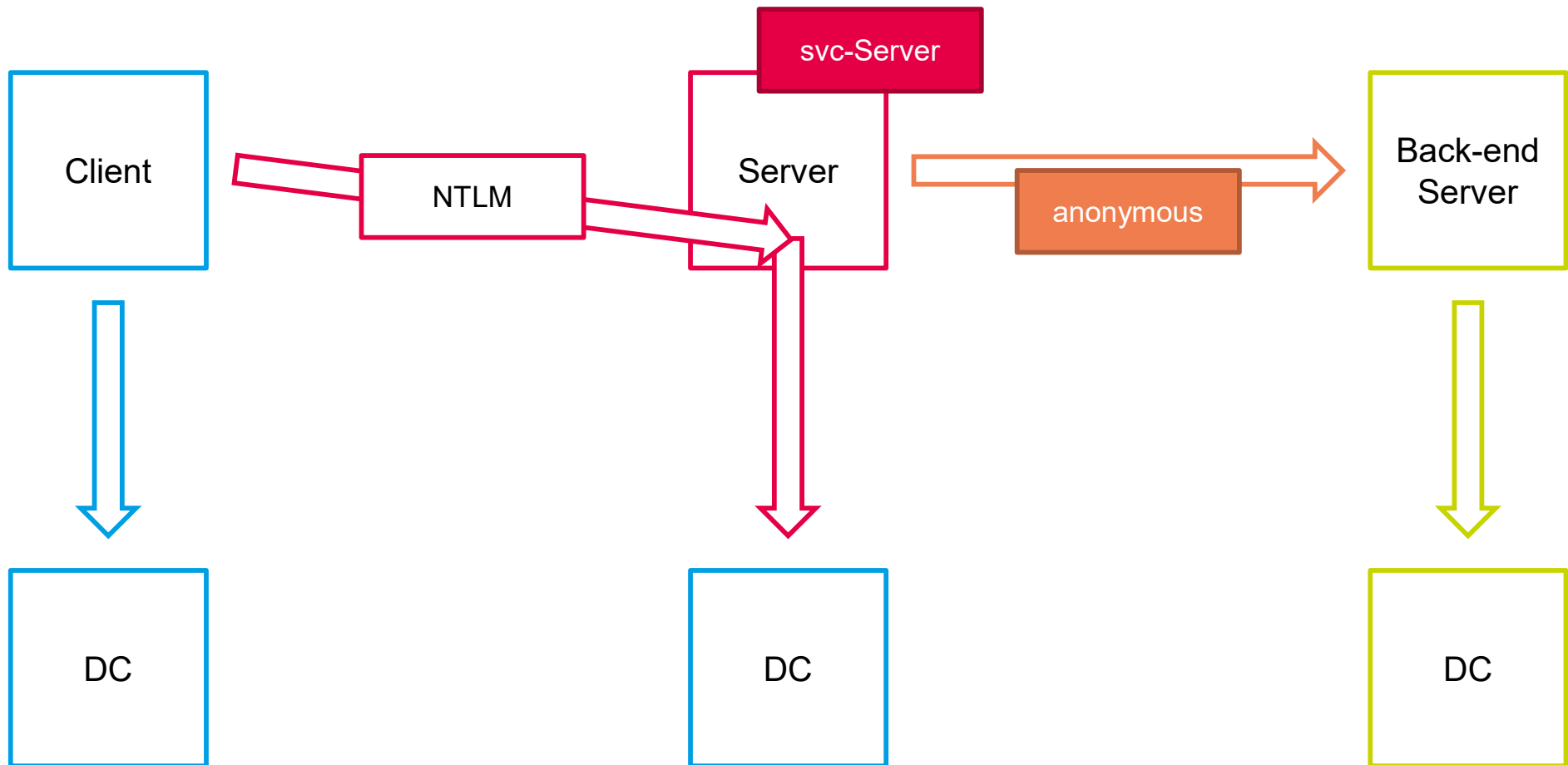
Access under **service** account



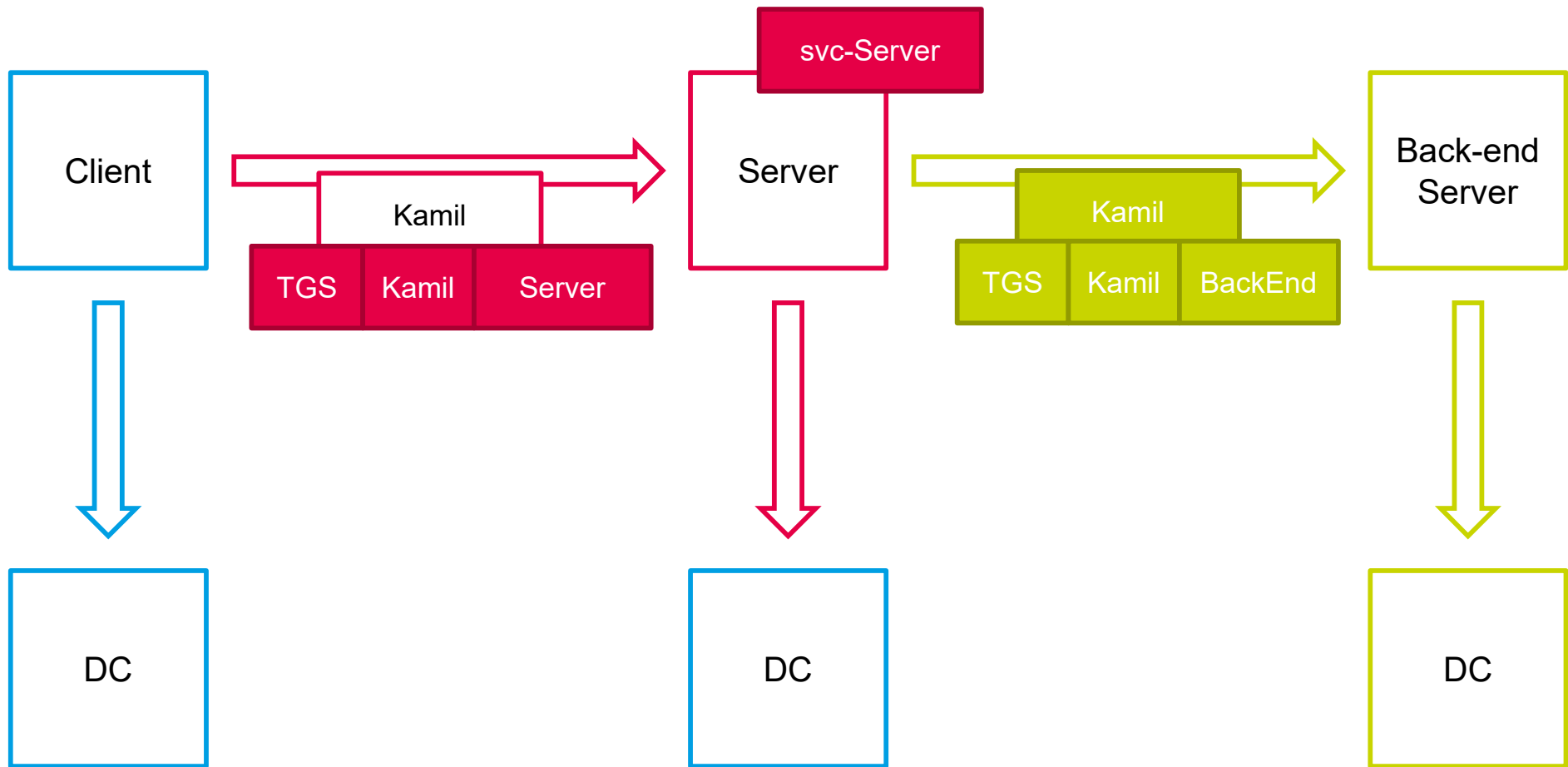
Access under the front-end **client user** account



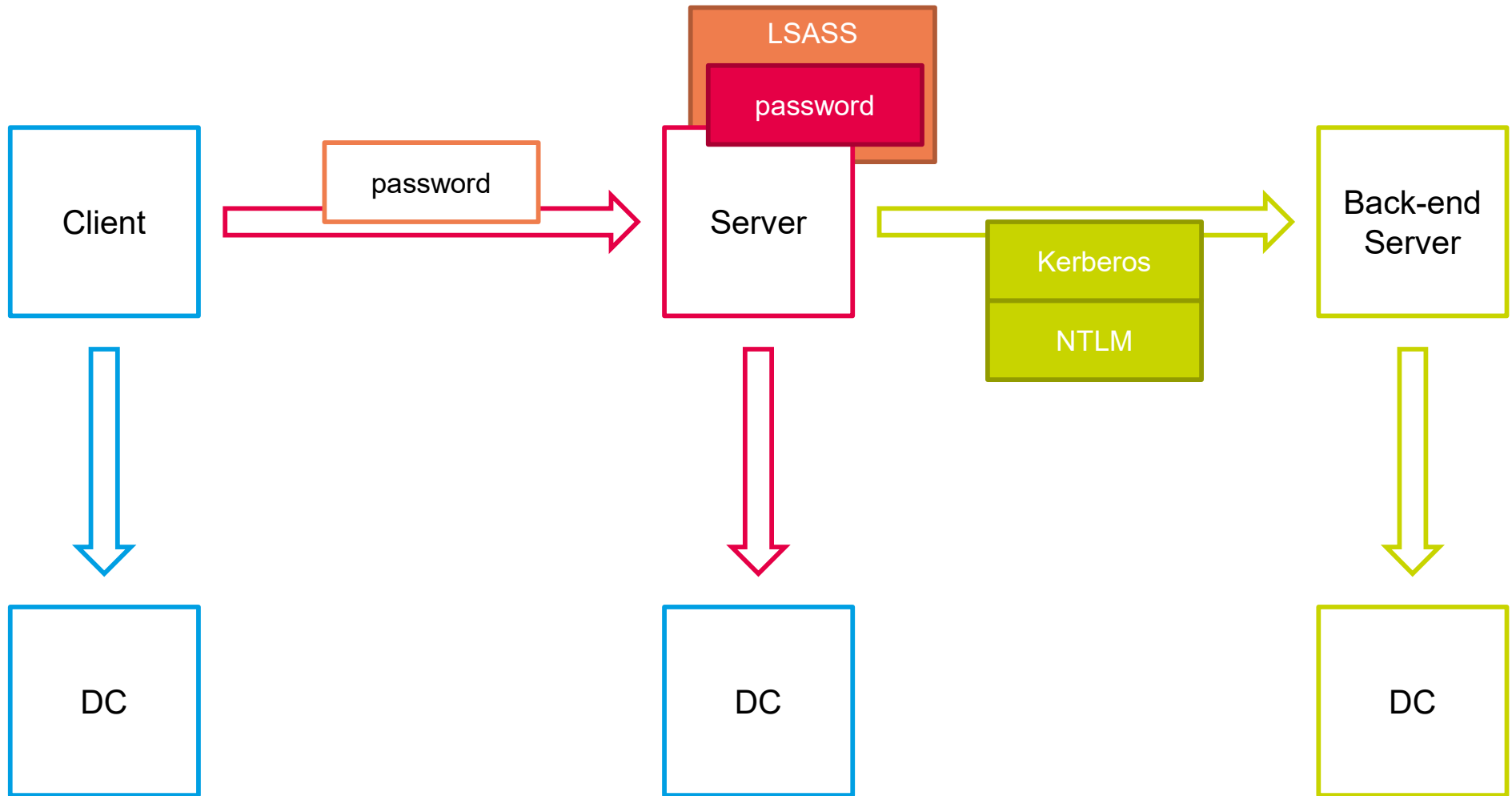
Nothing to forward with NTLM pass-through



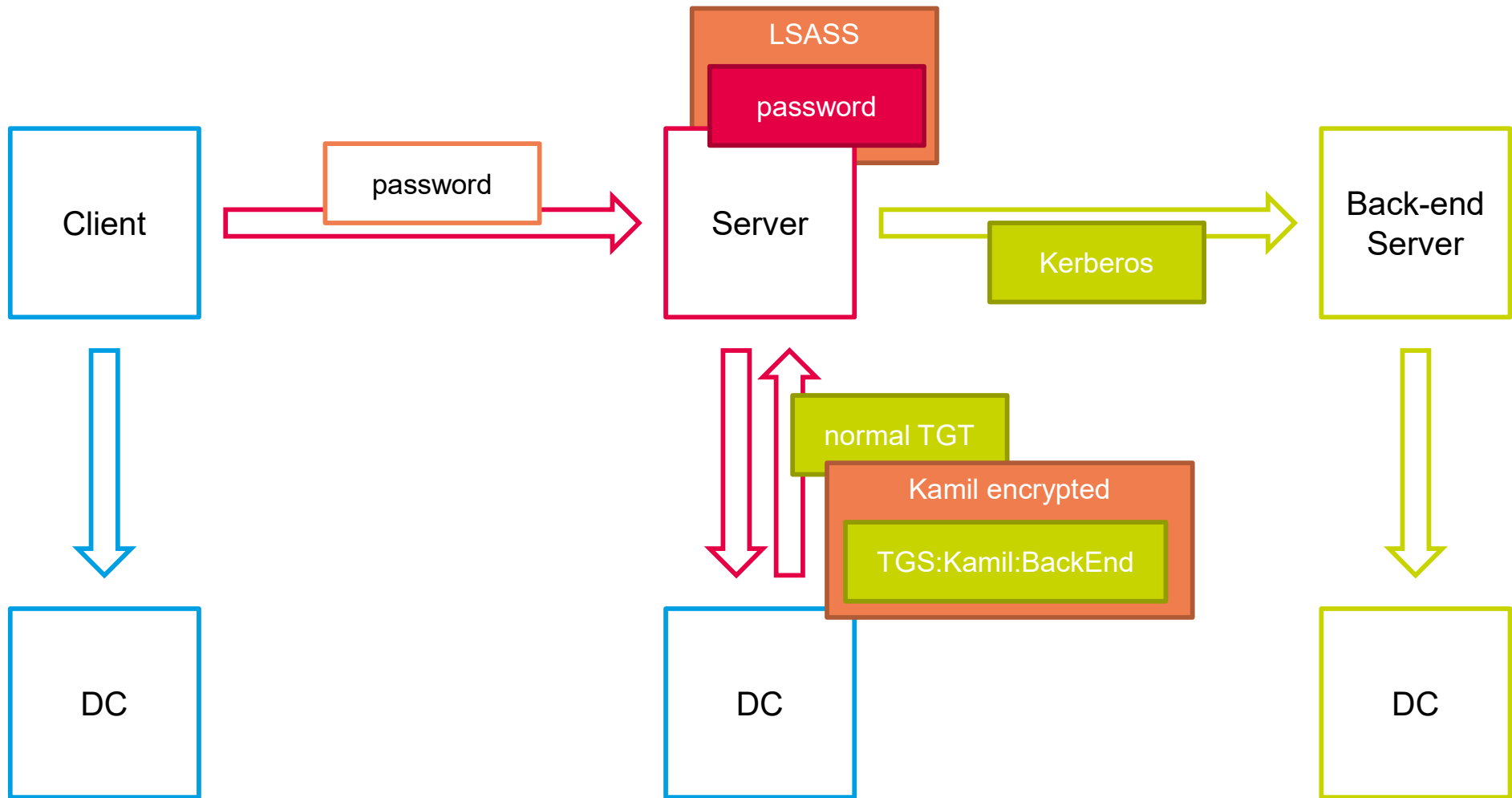
Kerberos TGS tickets required



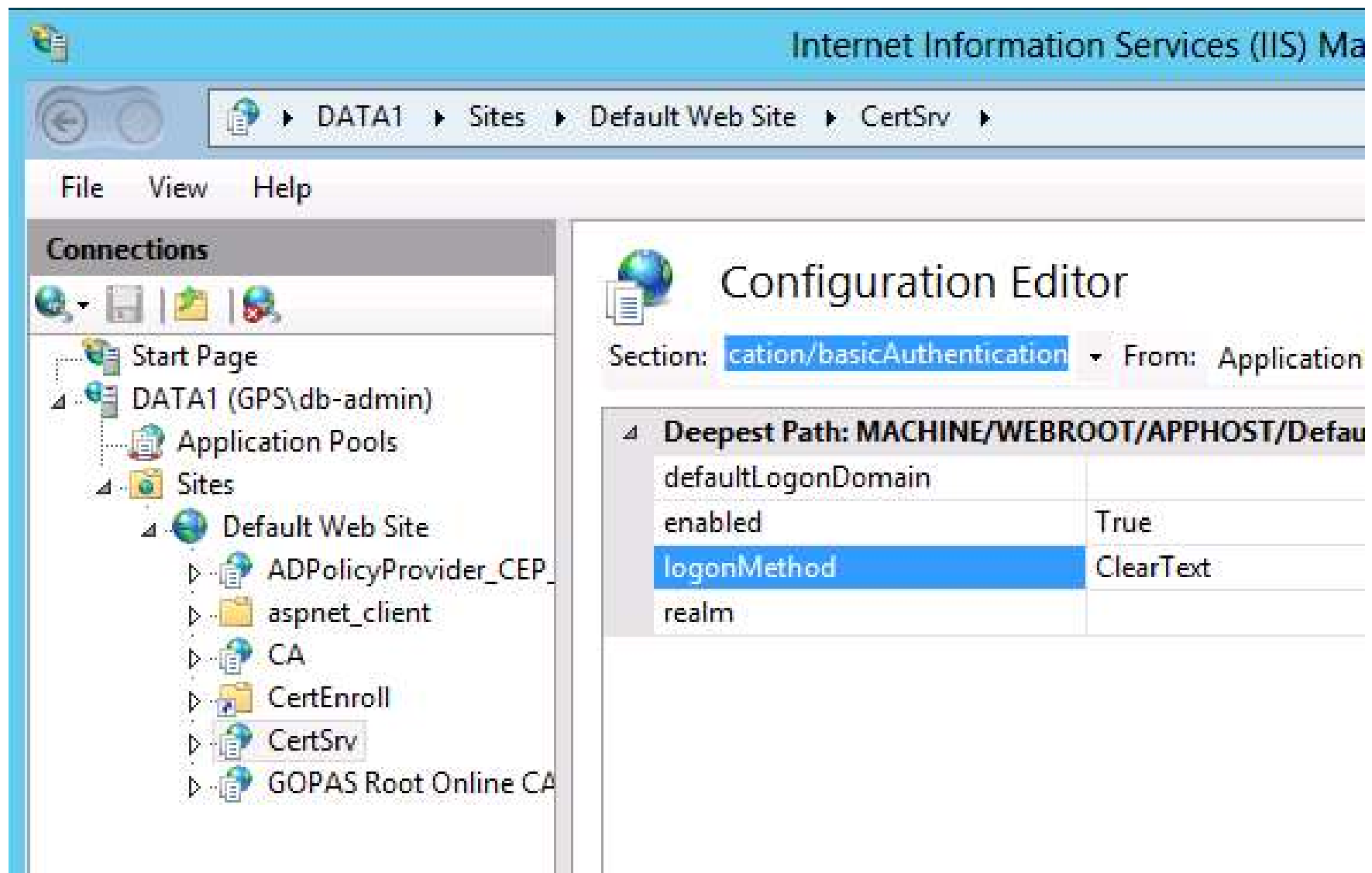
Basic delegation



Basic delegation



Side note: even basic delegation may sometimes not work
Verify the **ClearText** value of **logonMethod** is enabled



RDP requires basic delegation

- RDP is **basic** authentication
- Kerberos is used only to verify **server's identity** and not the client identity
 - normal full TGT generated on RDP server
- Problems
 - **Users** – must type password on each connect or store password
 - **Admins** – clean password transported and stored in memory

RDP RestrictedAdmin mode

- Kerberos TGS authentication of client only
- No full password transferred
- Limited delegation with system tickets injected

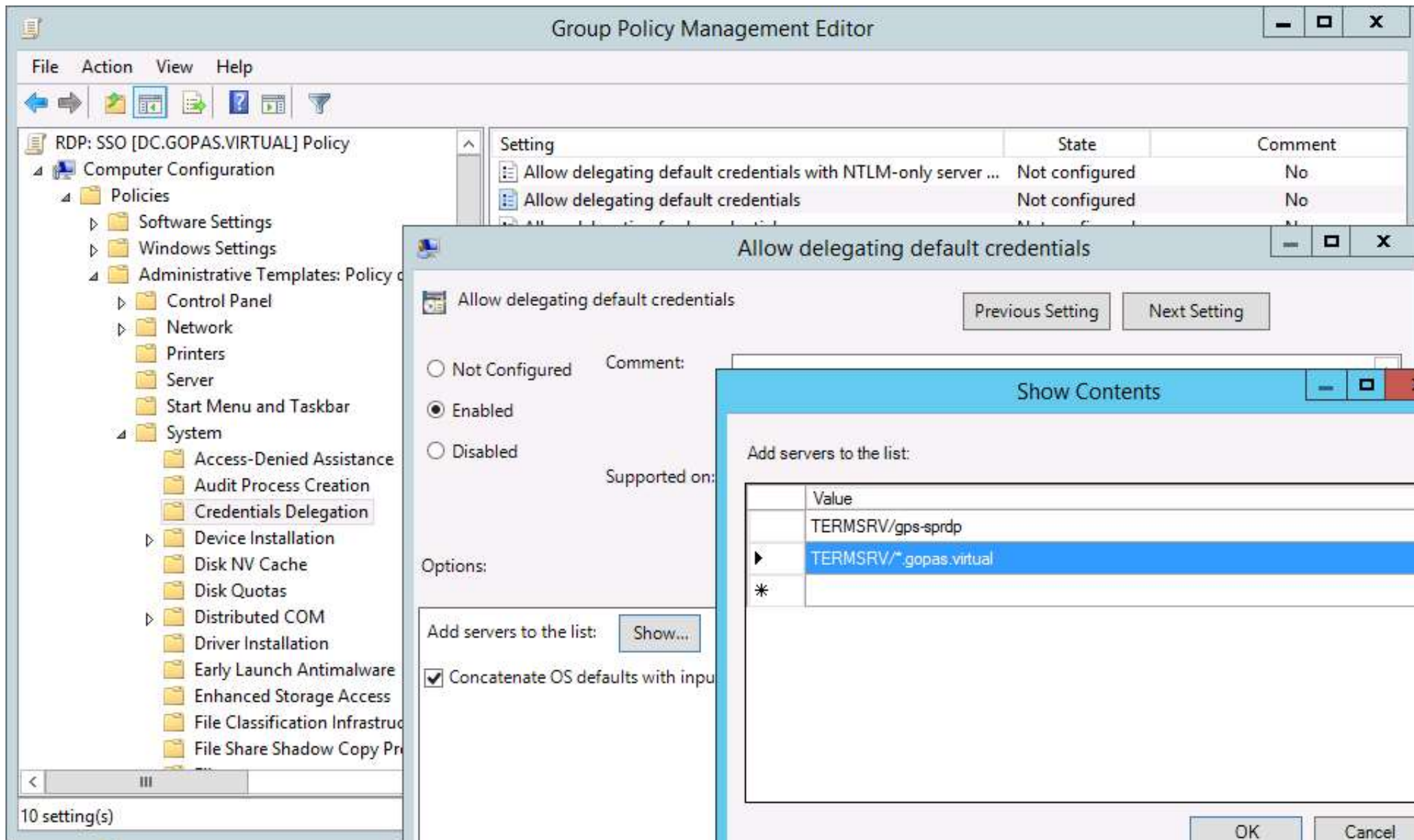
```
mstsc /restrictedAdmin
```

```
HKLM\System\CurrentControlSet\Control\Lsa
```

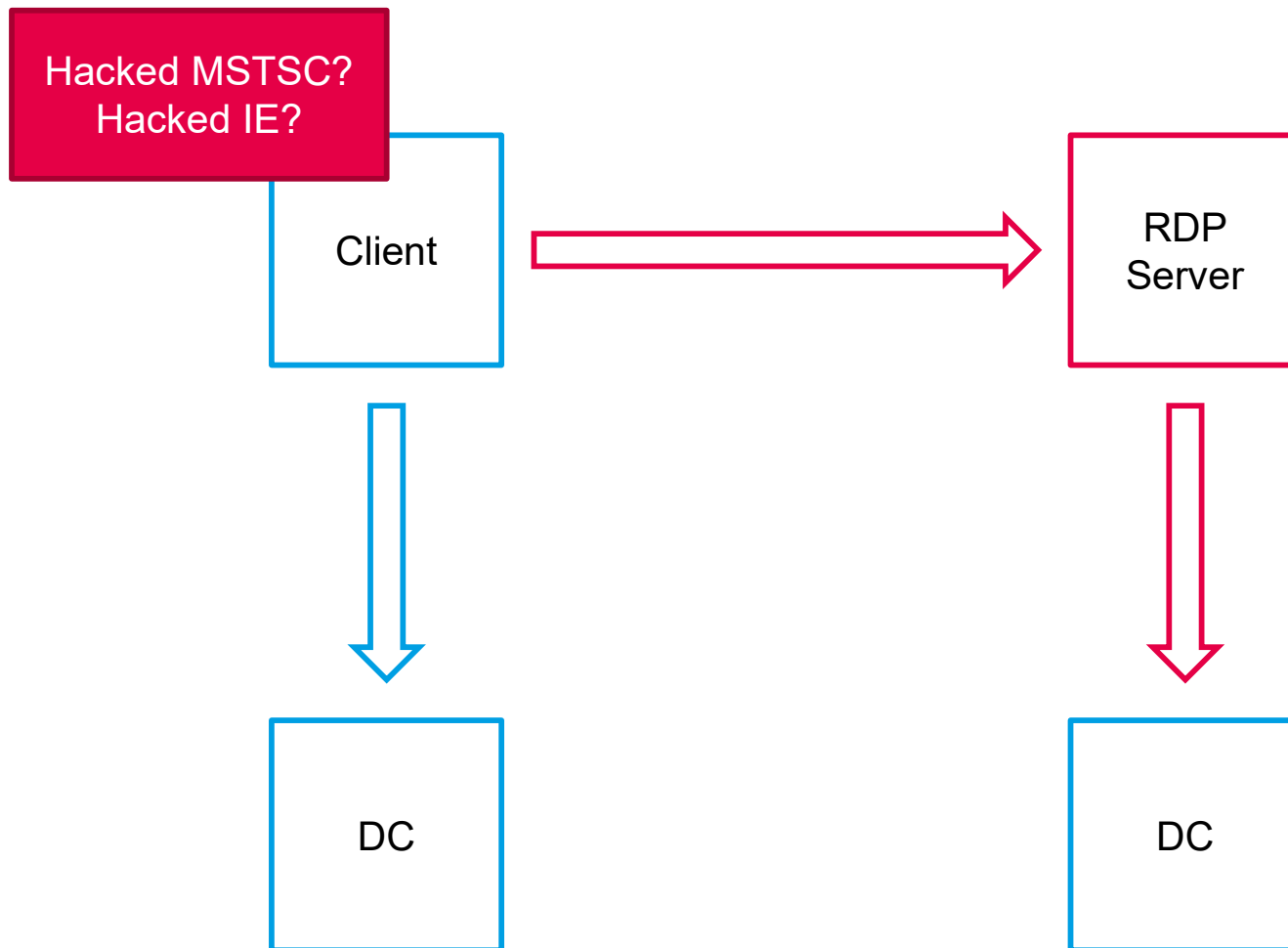
```
DisableRestrictedAdmin = 0
```

```
DisableRestrictedAdminOutboundCreds = 1
```

RDP SSO with Credentials Delegation settings for the client side

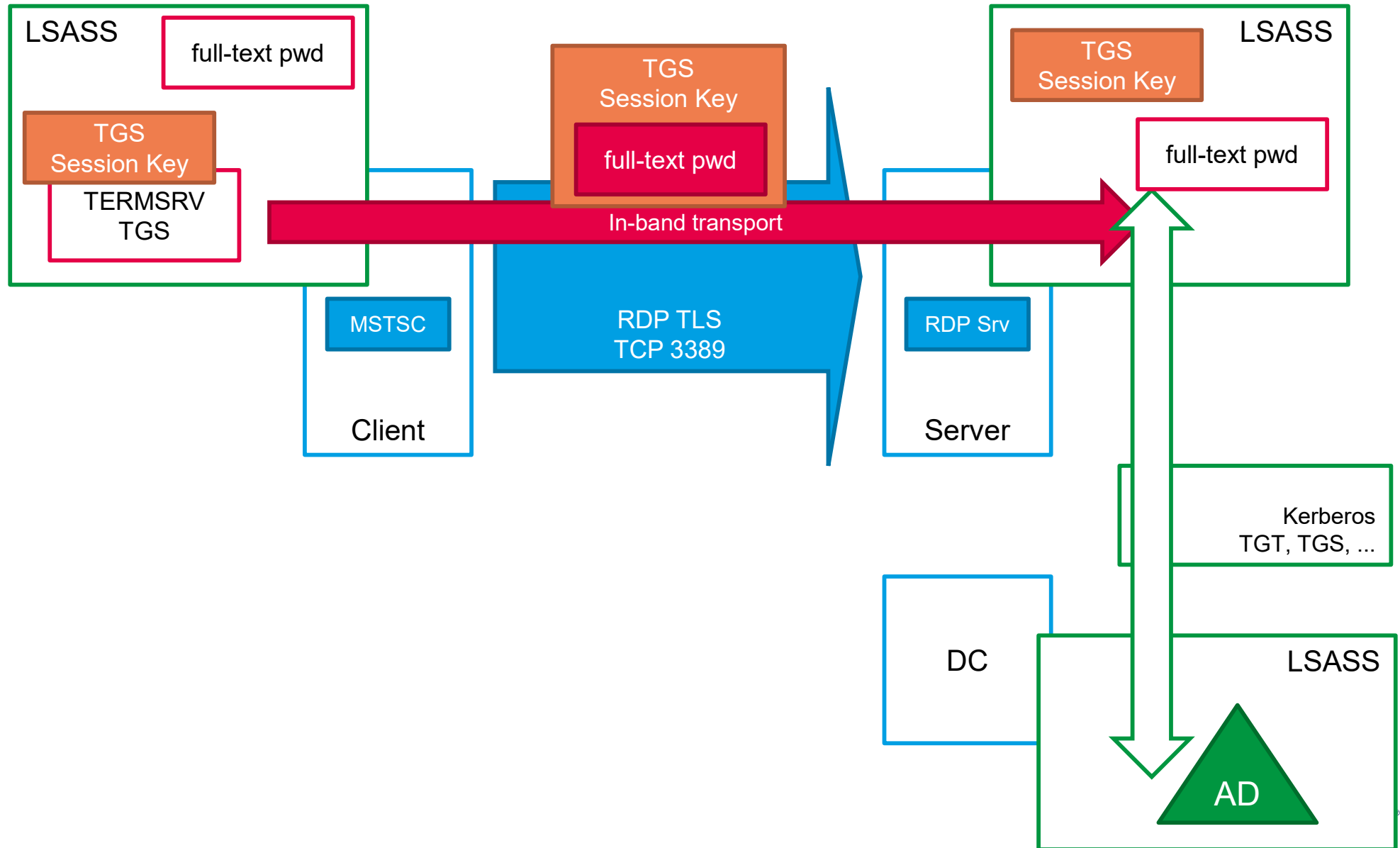


RDP SSO challenges on client?

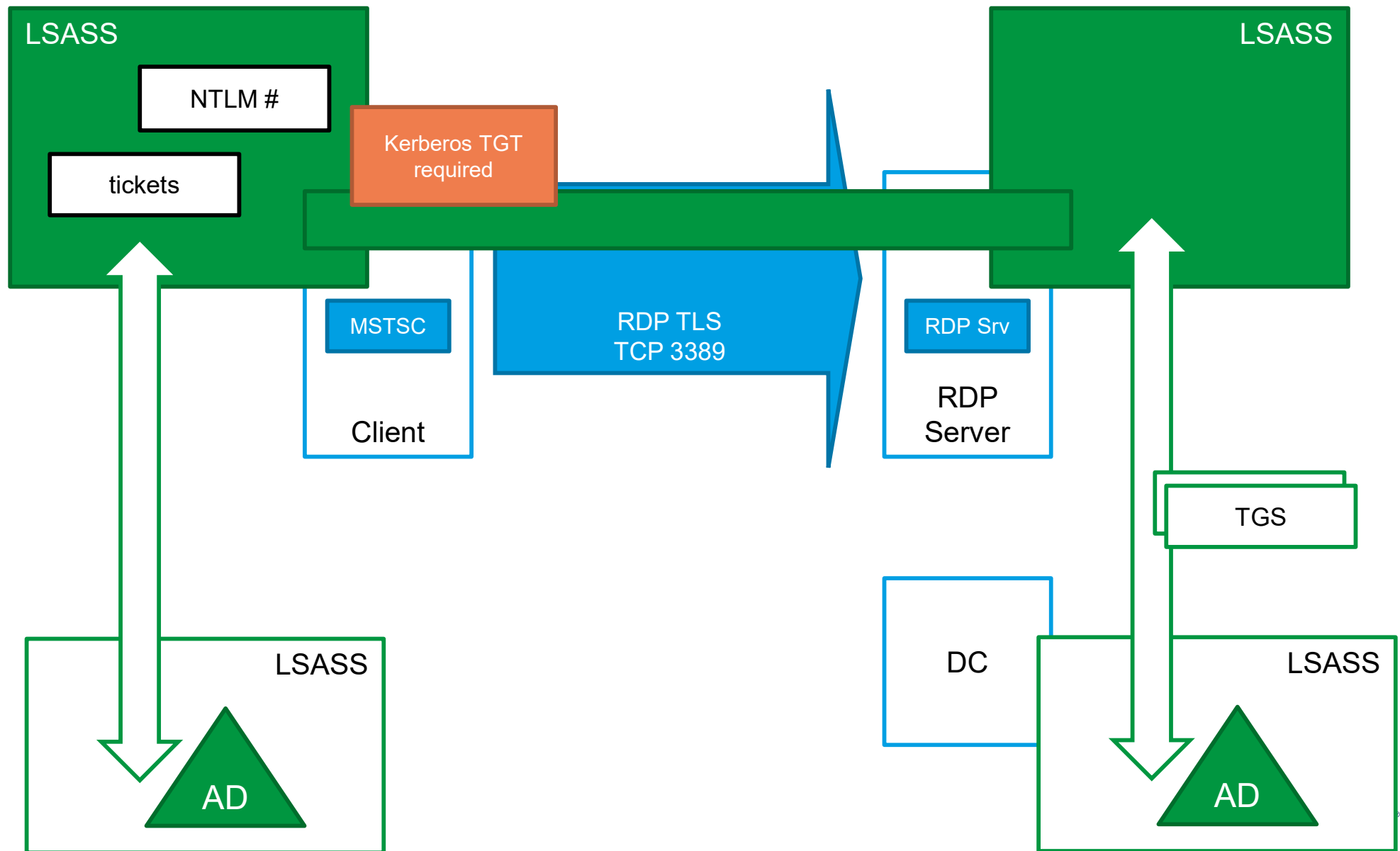


Credentials Delegation (CredSSP) security

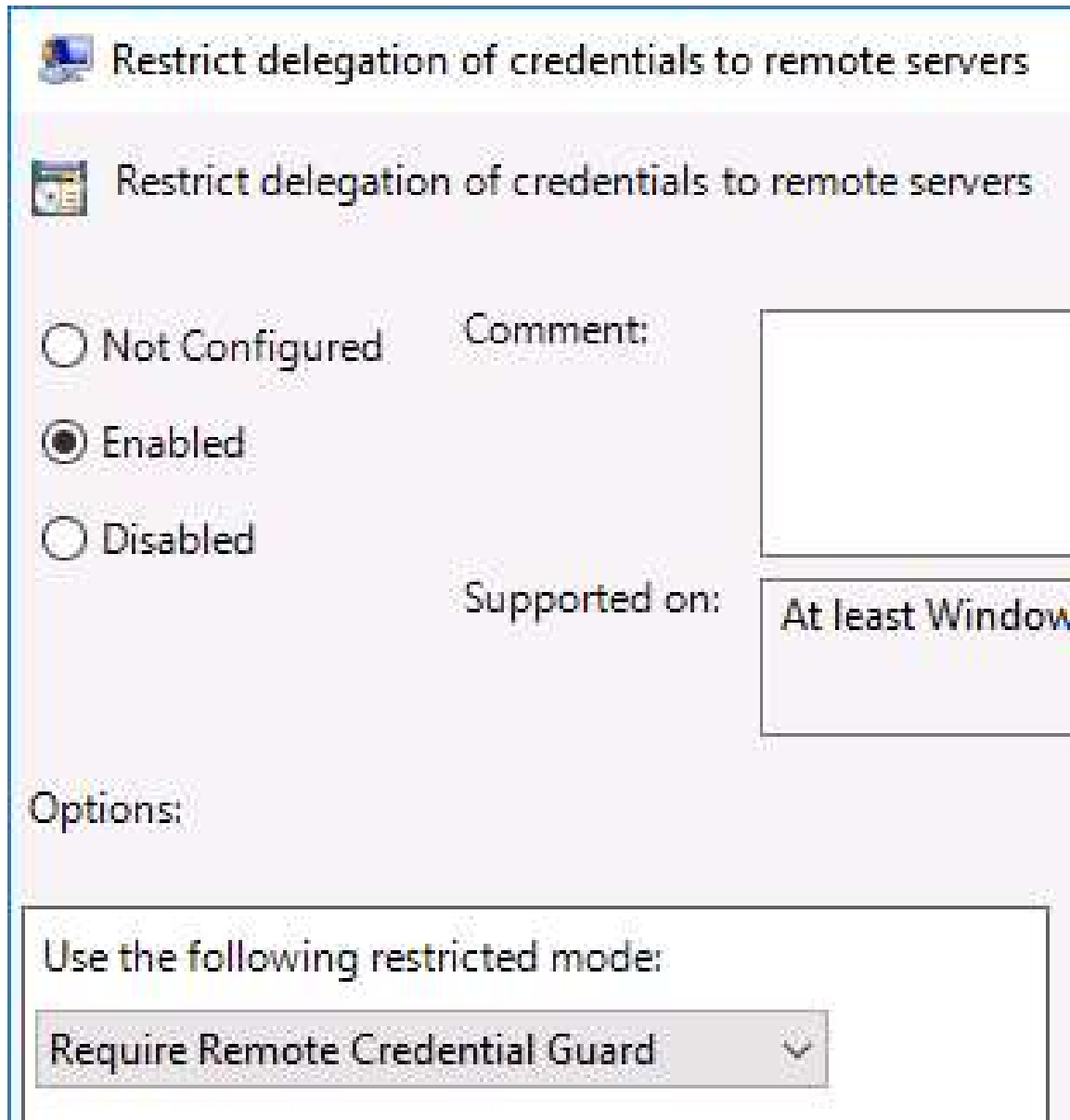
LSASS to LSASS encrypted transport



RemoteGuard for business users (10/2016+)



RemoteGuard for business users



The screenshot shows a configuration window for RemoteGuard. At the top, there is a title bar with a small icon and the text "Restrict delegation of credentials to remote servers". Below this, there is a section with a light purple background. It contains a header "Restrict delegation of credentials to remote servers" with a small icon. Underneath, there are three radio buttons: "Not Configured", "Enabled" (which is selected), and "Disabled". To the right of these radio buttons is a "Comment:" label followed by a text input field. Below the radio buttons is a "Supported on:" label followed by a text input field containing the text "At least Window". At the bottom of the configuration section, there is an "Options:" label. Below this, there is a section titled "Use the following restricted mode:" which contains a dropdown menu with the text "Require Remote Credential Guard" and a downward arrow.

Restrict delegation of credentials to remote servers

Restrict delegation of credentials to remote servers

☐ Not Configured Comment:

☒ Enabled

☐ Disabled

Supported on:

Options:

Use the following restricted mode:

Require Remote Credential Guard ▼

Secure RDP usage

- **user** business access to application terminal
 - **must double-hop**
 - RDP SSO
 - Windows 10/2016+ **/remoteGuard (GPO)**
- **admin** access to insecure machines
 - **must not double-hop**
 - Windows 7/2008R2+ **/restrictedAdmin**
 - **Enter-PSSession**

Kerberos **un**constrained delegation

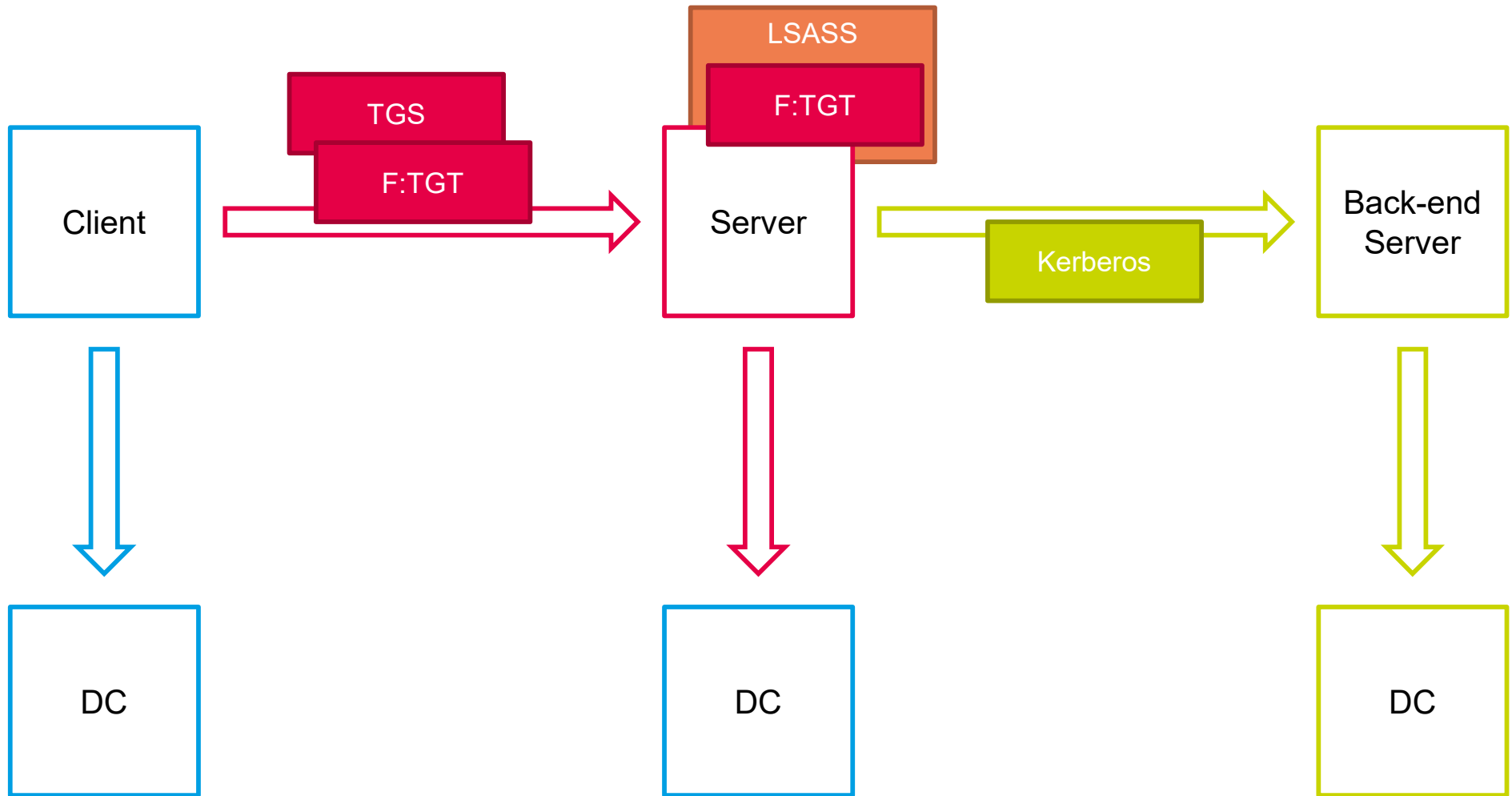
Trust this user/computer for delegation to any service (Kerberos only)

userAccountControl
flag
ADS_UF_TRUSTED_FOR_DELEGATION = 524288 =
0x80000

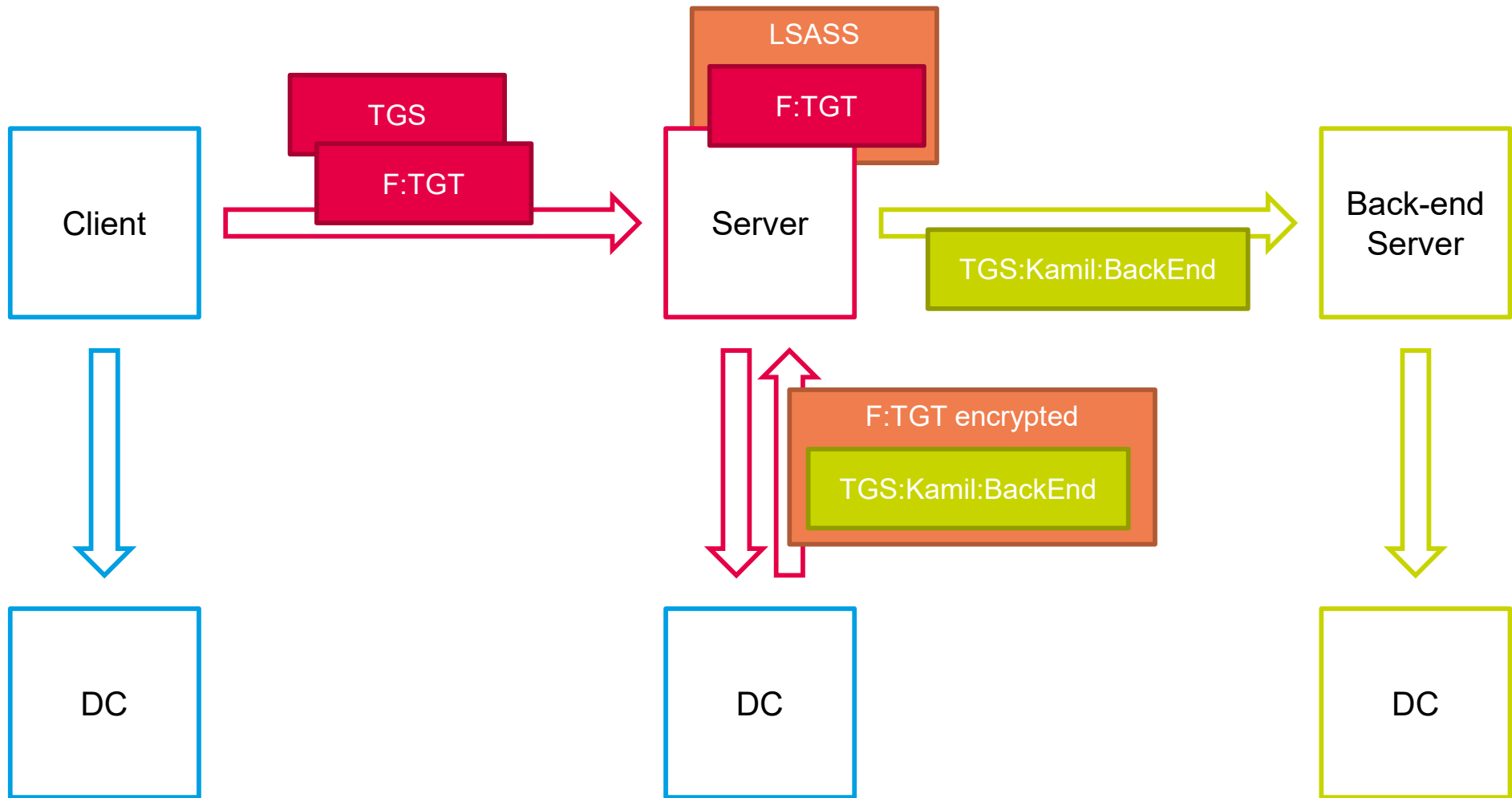
The screenshot shows the 'svc-portal Properties' dialog box with the 'Delegation' tab selected. The dialog has a title bar with a question mark and a close button. Below the title bar is a tabbed interface with the following tabs: Organization, Published Certificates, Member Of, Password Replication, Dial-in, Object, Security, Environment, Sessions, Remote control, Remote Desktop Services Profile, COM+, UNIX Attributes, Attribute Editor, General, Address, Account, Profile, Telephones, and Delegation. The 'Delegation' tab is active, displaying the following text: 'Delegation is a security-sensitive operation, which allows services to act on behalf of another user.' Below this text are three radio button options: 'Do not trust this user for delegation', 'Trust this user for delegation to any service (Kerberos only)' (which is selected), and 'Trust this user for delegation to specified services only'. Under the third option, there are two sub-options: 'Use Kerberos only' (selected) and 'Use any authentication protocol'. Below these options is the text 'Services to which this account can present delegated credentials:' followed by a table with four columns: 'Service Type', 'User or Computer', 'Port', and 'Service Name'. The table is currently empty.

Service Type	User or Computer	Port	Service Name
--------------	------------------	------	--------------

Kerberos unconstrained delegation (DFL 2000+)



Kerberos unconstrained delegation (DFL 2000+)



Unconstrained delegation allowed on TGS ticket and the F:TGT

```
#0> Client: kam1l @ GOPAS.VIRTUAL
Server: krbtgt/GOPAS.VIRTUAL @ GOPAS.VIRTUAL
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x60a10000 -> forwardable forwarded renewable pre_authent name_cano
Start Time: 1/24/2020 12:22:40 (local)
End Time: 1/24/2020 22:22:40 (local)
Renew Time: 1/31/2020 12:22:40 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x2 -> DELEGATION
Kdc Called: GPS-DC1.gopas.virtual

#1> Client: kam1l @ GOPAS.VIRTUAL
Server: krbtgt/GOPAS.VIRTUAL @ GOPAS.VIRTUAL
KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent name_cano
Start Time: 1/24/2020 12:22:40 (local)
End Time: 1/24/2020 22:22:40 (local)
Renew Time: 1/31/2020 12:22:40 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called: GPS-DC1.gopas.virtual

#2> Client: kam1l @ GOPAS.VIRTUAL
Server: HTTP/finance.gopas.cz @ GOPAS.VIRTUAL
KerbTicket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate nam
Start Time: 1/24/2020 12:22:40 (local)
End Time: 1/24/2020 22:22:40 (local)
Renew Time: 1/24/2020 12:22:40 (local)
```


Account is sensitive and cannot be delegated

- Always protect all administrative accounts
 - `userAccountControl` flag
`ADS_UF_NOT_DELEGATED`
`= 1048576 = 0x100000`
- Protected Users
 - blocks delegation since DFL 2012 R2

The screenshot shows the 'domain-admin Properties' dialog box with the 'Account' tab selected. The 'User logon name' is 'domain-admin' and the domain is '@GOPAS.virtual'. The 'User logon name (pre-Windows 2000)' is 'GPS\domain-admin'. The 'Logon Hours...' and 'Log On To...' buttons are visible. The 'Unlock account' checkbox is unchecked. Under 'Account options', the 'Account is sensitive and cannot be delegated' checkbox is checked and highlighted with a red rectangle. The 'Use Kerberos DES encryption types for this account' checkbox is also checked. The 'Account expires' section shows 'Never' selected. The 'OK', 'Cancel', 'Apply', and 'Help' buttons are at the bottom.

Member Of	Dial-in	Environment	Sessions
Remote control	Remote Desktop Services Profile		COM+
General	Address	Account	Profile
		Telephones	Organization

User logon name:
domain-admin @GOPAS.virtual

User logon name (pre-Windows 2000):
GPS\domain-admin

Logon Hours... Log On To...

☐ Unlock account

Account options:

- ☐ Account is disabled
- ☐ Smart card is required for interactive logon
- ☒ Account is sensitive and cannot be delegated
- ☒ Use Kerberos DES encryption types for this account

Account expires

☒ Never

☐ End of: 9. ledna 2016

OK Cancel Apply Help

Unconstrained delegation for user accounts from different forests

- disabled by default since DC 2016+
- enable on the trust manually on both sides

```
netdom.exe trust <localDomain>  
/domain:<remoteDomain>  
/EnableTGtDelegation:Yes
```

Unconstrained delegation with Chrome and Edge (Chromium)

- HKEY_LOCAL_MACHINE\SOFTWARE\Policies\Google\Chrome
 - AuthNegotiateDelegateWhitelist = REG_SZ
 - comma separated URLs, wildcards allowed
- HKEY_LOCAL_MACHINE\Software\Policies\Microsoft\Edge
 - AuthNegotiateDelegateAllowlist = REG_SZ
 - comma separated URLs, wildcards allowed
- AuthNegotiateDelegateAllowlist case sensitive

Unconstrained delegation with FireFox

```
about:config
```

```
# NEGOTIATE (Kerberos) at all
```

```
network.negotiate-auth.trusted-uris  
    gopas.cz,gopas.virtual,canteen
```

```
# forward F:TGT to URIs
```

```
network.negotiate-auth.delegation-uris  
    gopas.cz,gopas.virtual,canteen
```

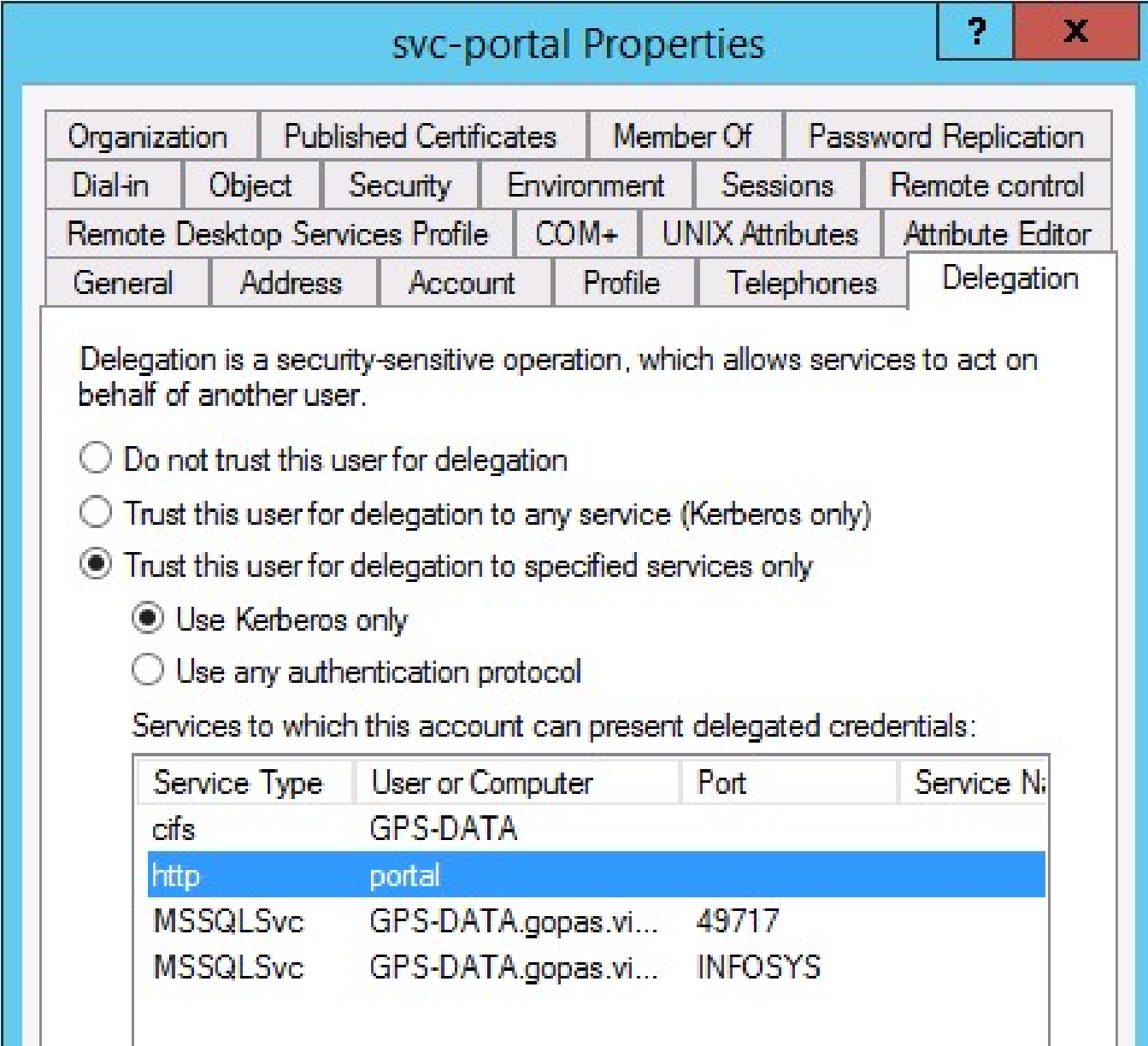
Double-hop security compared

Delegation form	Notes
basic delegation	no SSO must type on insecure client steal password on client (user) steal password on server SSO injection
RDP SSO CredSSP credential delegation	SSO password kept in LSASS memory steal password on client (admin) steal password on server SSO injection
RDP RemoteGuard	SSO TGT only connected to server steal TGT on client (admin) SSO injection
Kerberos unconstrained delegation	SSO TGT forwarded to server steal TGT on client (admin) steal TGT on server SSO injection block on accounts (Protected Users)

Kerberos constrained delegation

Trust this user/computer for delegation to specified services only (use Kerberos only)

msDS-
AllowedToDelegateTo
attribute



svc-portal Properties

Organization	Published Certificates	Member Of	Password Replication
Dial-in	Object	Security	Environment
Sessions	Remote control	Remote Desktop Services Profile	COM+
UNIX Attributes	Attribute Editor	General	Address
Account	Profile	Telephones	Delegation

Delegation is a security-sensitive operation, which allows services to act on behalf of another user.

☐ Do not trust this user for delegation

☐ Trust this user for delegation to any service (Kerberos only)

☒ Trust this user for delegation to specified services only

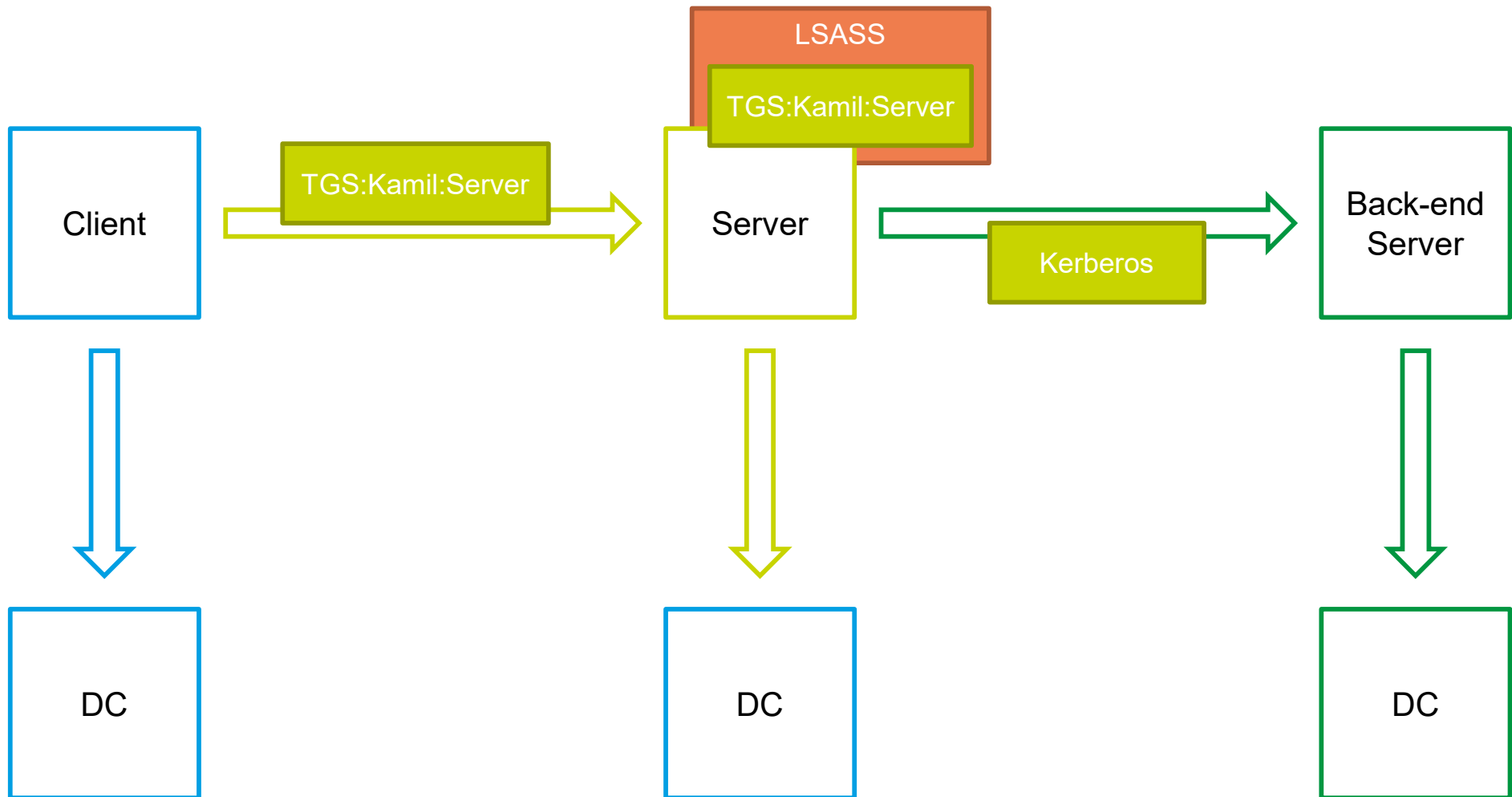
☒ Use Kerberos only

☐ Use any authentication protocol

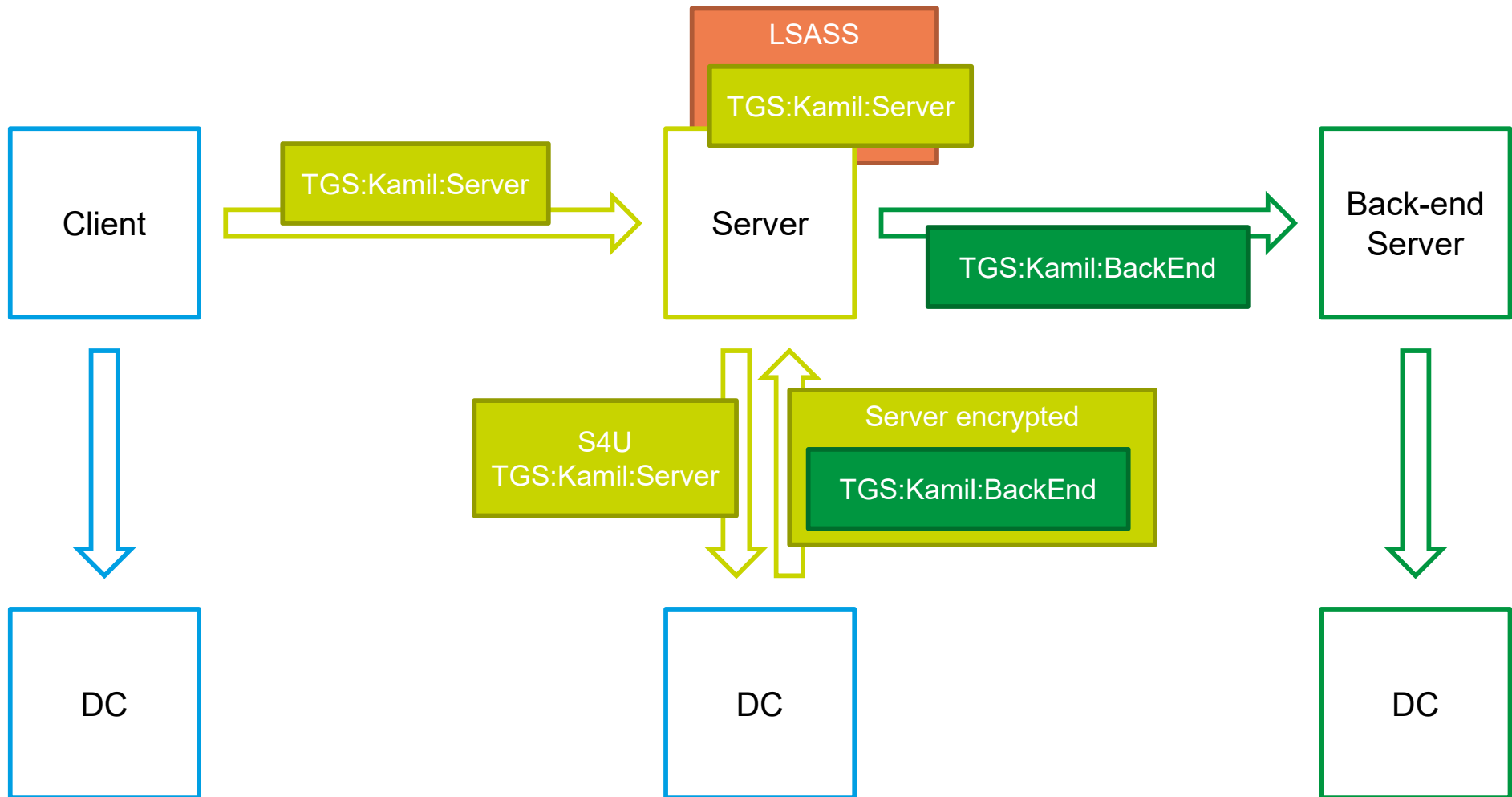
Services to which this account can present delegated credentials:

Service Type	User or Computer	Port	Service Name
cifs	GPS-DATA		
http	portal		
MSSQLSvc	GPS-DATA.gopas.vi...	49717	
MSSQLSvc	GPS-DATA.gopas.vi...	INFOSYS	

Kerberos constrained delegation (DFL 2003+)



Kerberos constrained delegation (DFL 2003+)



Constrained delegation requirements

- **Server** account must read tokenGroupsGlobalAndUniversal attribute
 - Windows Authorization Access Group (WAAG)
- Client **user account** must **not** have delegation prohibited userAccountControl attribute
 - $\text{ADS_UF_NOT_DELEGATED} = 1048576 = 0x100000$
- If using IIS Kernel Mode Authentication + AD user account
 - must enable **useAppPoolCredentials**

Best practice hints for Kerberos constrained delegation

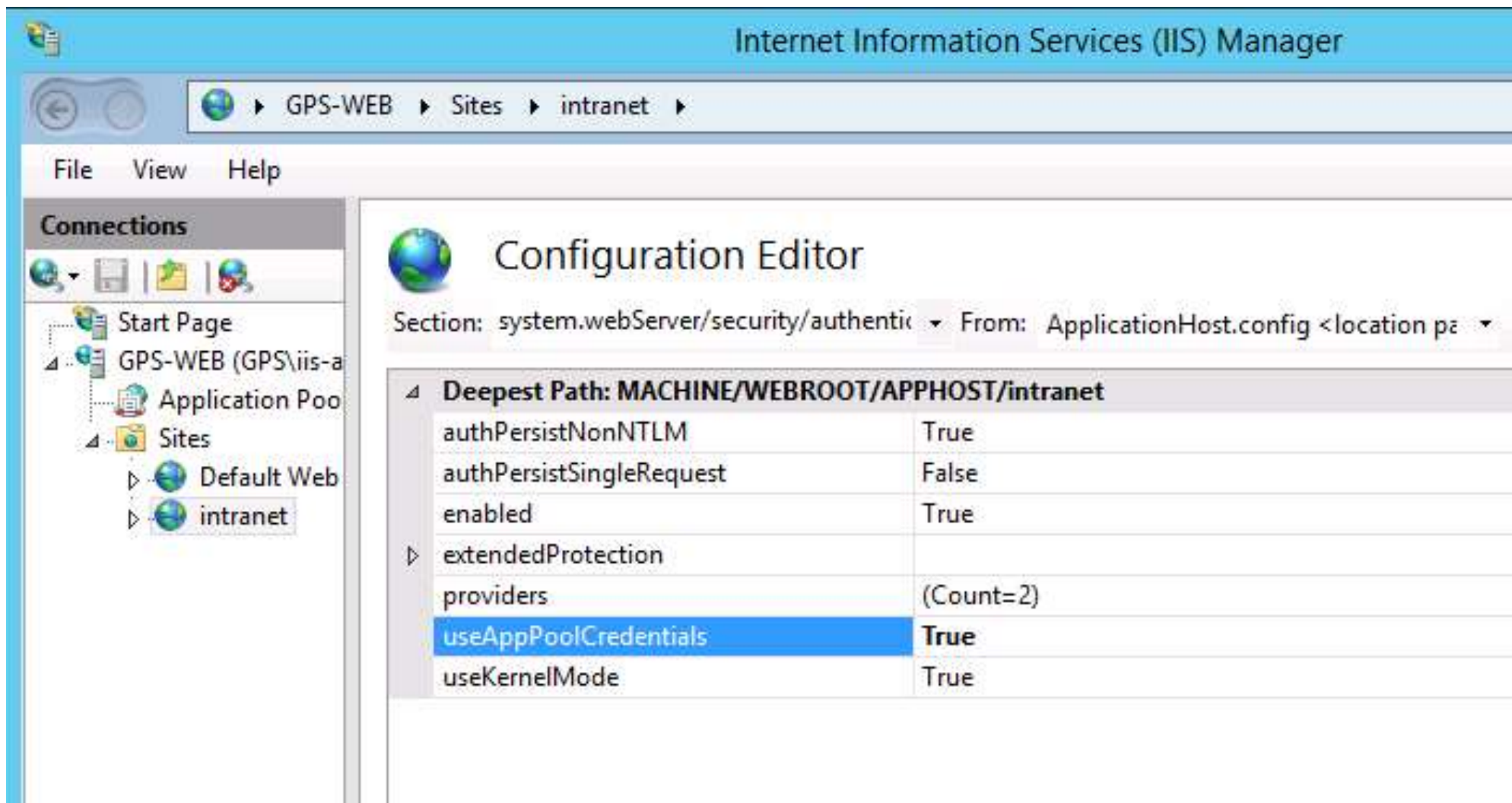
- Full restart of the Server always
- Static TCP port for SQL servers
- With DFL 2003 explicitly disable AES for the Server
- Protect sensitive accounts against being delegated

Constrained delegation to SMB server account

- front-end SPN on user/gmsa account
 - no domain/gmsa account
 - no domain/gmsa account + Kernel Mode + UseAppPoolCredentials
- front-end SPN on computer account
 - ok domain/gmsa account + Kernel Mode
 - ◆ since 2012+
 - ok ApplicationPoolIdentity
 - ◆ since 2012+
 - ok Network Service
 - ◆ since 2012+
 - ok SYSTEM
 - ◆ since ever

Delegation in IIS with Kernel mode authentication and useAppPoolCredentials

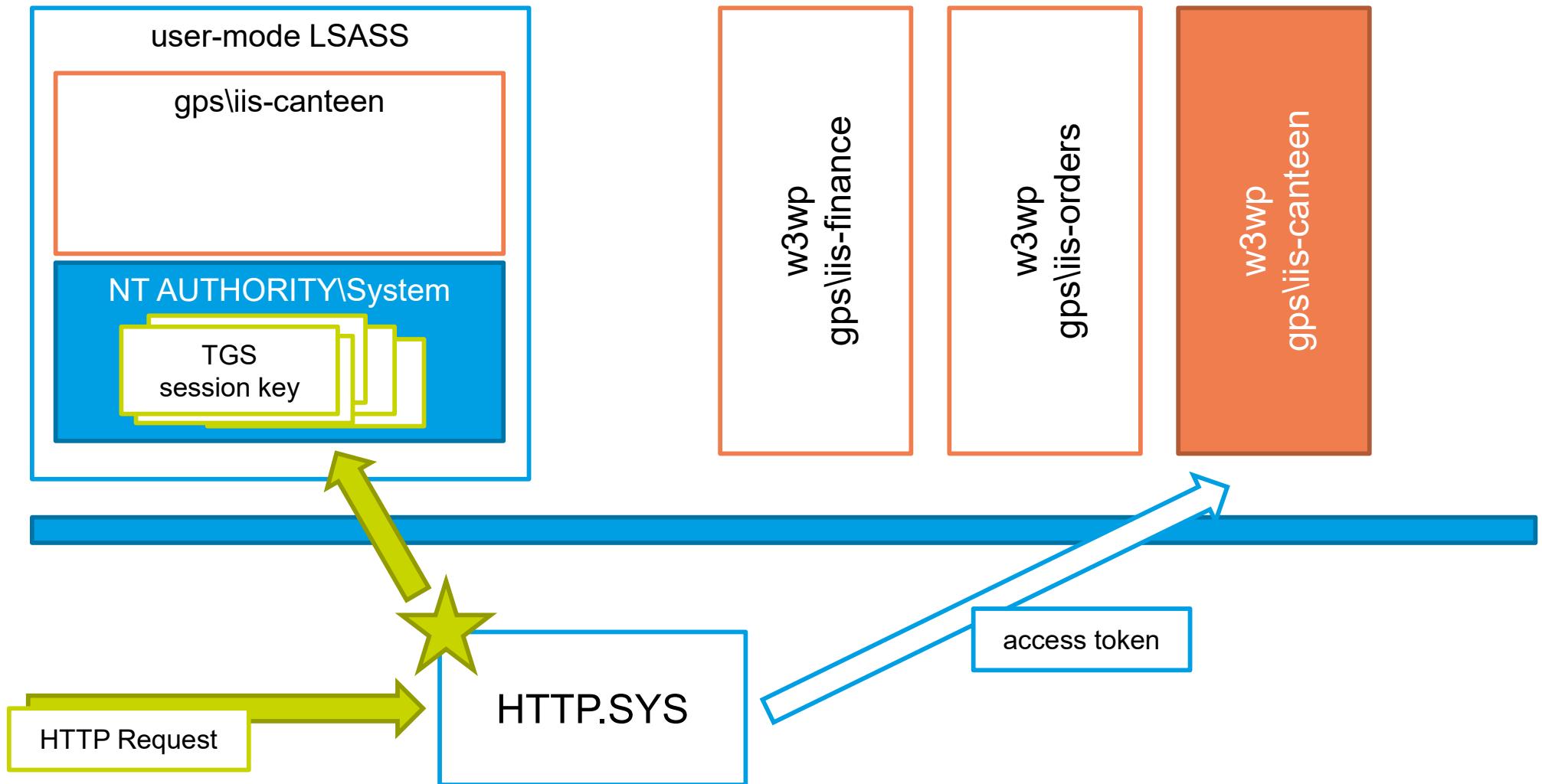
- system/webServer/security/authentication/windowsAuthentication



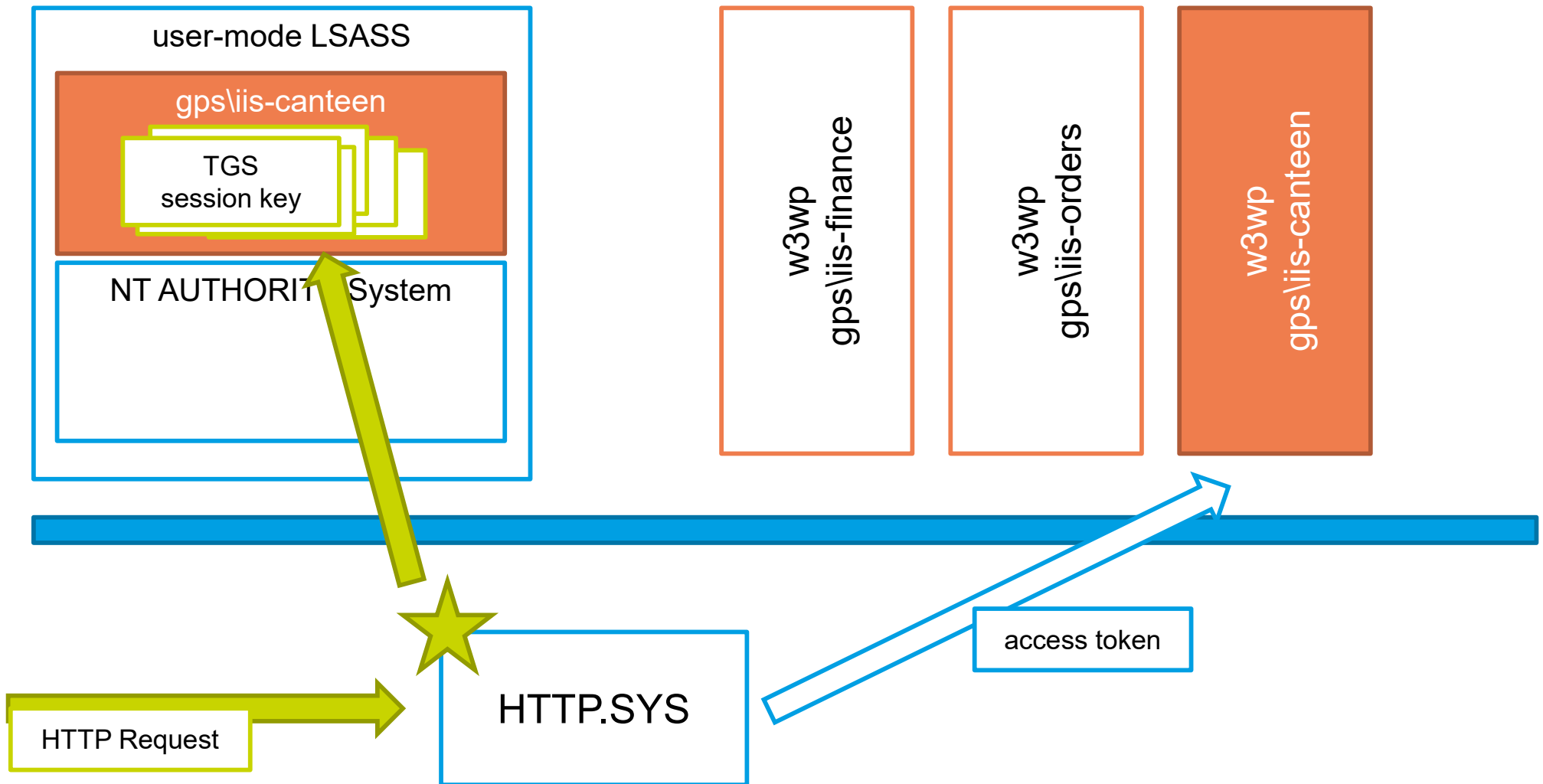
The screenshot shows the Internet Information Services (IIS) Manager interface. The breadcrumb navigation at the top indicates the path: GPS-WEB > Sites > intranet. The left-hand 'Connections' pane shows a tree view with 'Start Page', 'GPS-WEB (GPS\iis-a)', 'Application Poo', 'Sites', 'Default Web', and 'intranet'. The 'intranet' site is selected. The main 'Configuration Editor' pane shows the configuration for the selected site. The 'Section' is 'system.webServer/security/authentication/windowsAuthentication' and the 'From' is 'ApplicationHost.config <location path=...>'. The configuration table below shows the following settings:

Deepest Path: MACHINE/WEBROOT/APPHOST/intranet	
authPersistNonNTLM	True
authPersistSingleRequest	False
enabled	True
extendedProtection	
providers	(Count=2)
useAppPoolCredentials	True
useKernelMode	True

useKernelMode only



useKernelMode + useAppPoolCredentials



Account is sensitive and cannot be delegated

userAccountControl flag

ADS_UF_NOT_DELEGATED
= 1048576 = 0x100000

Protected Users group
blocks delegation only since
2012 R2 DFL

domain-admin Properties

Published Certificates	Member Of	Password Replication	Dial-in	Object
Security	Environment	Sessions	Remote control	
Remote Desktop Services Profile	COM+	UNIX Attributes	Attribute Editor	
General	Address	Account	Profile	Telephones
			Organization	

User logon name:

domain-admin @gopas.virtual

User logon name (pre-Windows 2000):

GPS\ domain-admin

Logon Hours... Log On To...

☐ Unlock account

Account options:

- ☐ Account is disabled
- ☐ Smart card is required for interactive logon
- ☒ Account is sensitive and cannot be delegated
- ☐ Use Kerberos DES encryption types for this account

Delegation disabled on sensitive accounts

```
C:\> Select Administrator: C:\Windows\system32\cmd.exe

Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x2 -> DELEGATION
Kdc Called: GPS-DC1.gopas.virtual

#1> Client: kamil @ GOPAS.VIRTUAL
Server: krbtgt/GOPAS.VIRTUAL @ GOPAS.VIRTUAL
Kerberos Ticket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0x40e10000 -> forwardable renewable initial pre_authent
Start Time: 4/18/2019 11:46:15 (local)
End Time: 4/18/2019 21:46:15 (local)
Renew Time: 4/25/2019 11:46:15 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called: GPS-DC1

#2> Client: kamil @ GOPAS.VIRTUAL
Server: HTTP/finance.gopas.cz @ GOPAS.VIRTUAL
Kerberos Ticket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0x40a10000 -> forwardable renewable pre_authent name_cache
Start Time: 4/18/2019 11:46:24 (local)
End Time: 4/18/2019 21:46:15 (local)
Renew Time: 4/25/2019 11:46:15 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: GPS-DC1.gopas.virtual

C:\> Select Administrator: cmd (running as gps\domain-admin)

Cached Tickets: (2)

#0> Client: domain-admin @ GOPAS.VIRTUAL
Server: krbtgt/GOPAS.VIRTUAL @ GOPAS.VIRTUAL
Kerberos Ticket Encryption Type: RSADSI RC4-HMAC(NT)
Ticket Flags 0xe10000 -> renewable initial pre_authent
Start Time: 4/18/2019 11:46:56 (local)
End Time: 4/18/2019 21:46:56 (local)
Renew Time: 4/25/2019 11:46:56 (local)
Session Key Type: RSADSI RC4-HMAC(NT)
Cache Flags: 0x1 -> PRIMARY
Kdc Called: GPS-DC1

#1> Client: domain-admin @ GOPAS.VIRTUAL
Server: HTTP/finance.gopas.cz @ GOPAS.VIRTUAL
Kerberos Ticket Encryption Type: AES-256-CTS-HMAC-SHA1-96
Ticket Flags 0xa10000 -> renewable pre_authent name_cache
Start Time: 4/18/2019 11:47:08 (local)
End Time: 4/18/2019 21:46:56 (local)
Renew Time: 4/25/2019 11:46:56 (local)
Session Key Type: AES-256-CTS-HMAC-SHA1-96
Cache Flags: 0
Kdc Called: GPS-DC1.gopas.virtual
```

The delegation tab is not visible unless there is at least one SPN of any kind

The screenshot shows the 'svc-portal Properties' dialog box. The 'Delegation' tab is selected in the tab bar at the bottom. The 'Multi-valued String Editor' is open, showing the 'Attribute' as 'servicePrincipalName'. The 'Value to add' field is empty. The 'Values' list contains one entry, 'dummy/svc-portal', which is highlighted with a red dashed rectangle. The 'Add' and 'Remove' buttons are visible next to the 'Value to add' and 'Values' fields respectively.

Organization	Published Certificates	Member Of	Password Replication
Dial-in	Object	Security	Environment
Sessions	Remote control	General	Address
Account	Profile	Telephones	Delegation
Remote Desktop Services Profile	COM+	UNIX Attributes	Attribute Editor

Multi-valued String Editor

Attribute: servicePrincipalName

Value to add:

Add

Values:

dummy/svc-portal

Remove

Kerberos constrained delegation with protocol transition

Trust this user/computer for delegation to specifies services only (use any authentication protocol)

msDS-
AllowedToDelegateTo
attribute
+
userAccountControl flag
ADS_UF_TRUSTED_FOR_DELEGATION =
524288 = 0x80000

svc-portal Properties

Organization	Published Certificates	Member Of	Password Replication		
Dial-in	Object	Security	Environment	Sessions	Remote control
Remote Desktop Services Profile	COM+	UNIX Attributes	Attribute Editor		
General	Address	Account	Profile	Telephones	Delegation

Delegation is a security-sensitive operation, which allows services to act on behalf of another user.

☐ Do not trust this user for delegation

☐ Trust this user for delegation to any service (Kerberos only)

☒ Trust this user for delegation to specified services only

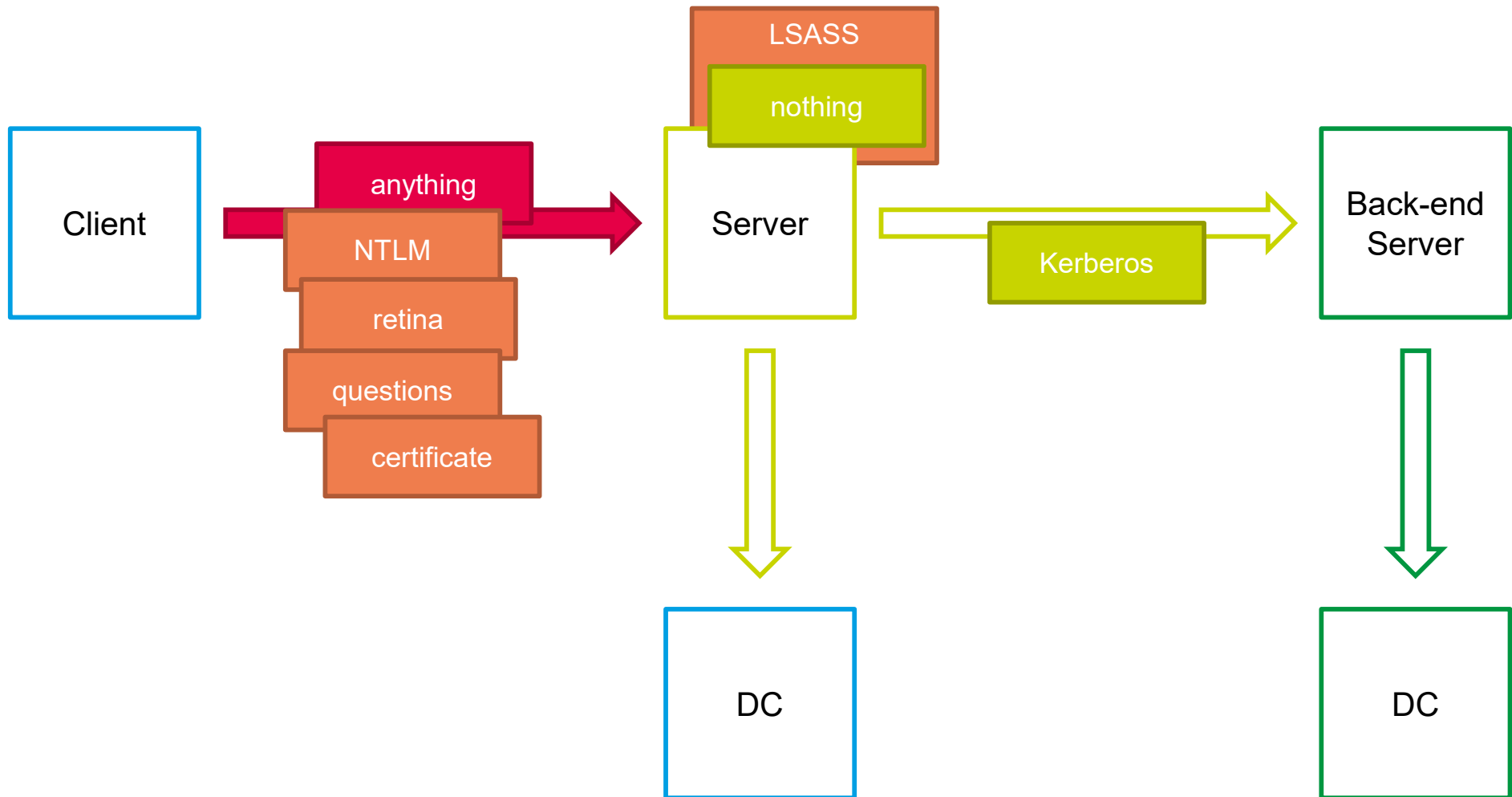
☐ Use Kerberos only

☒ Use any authentication protocol

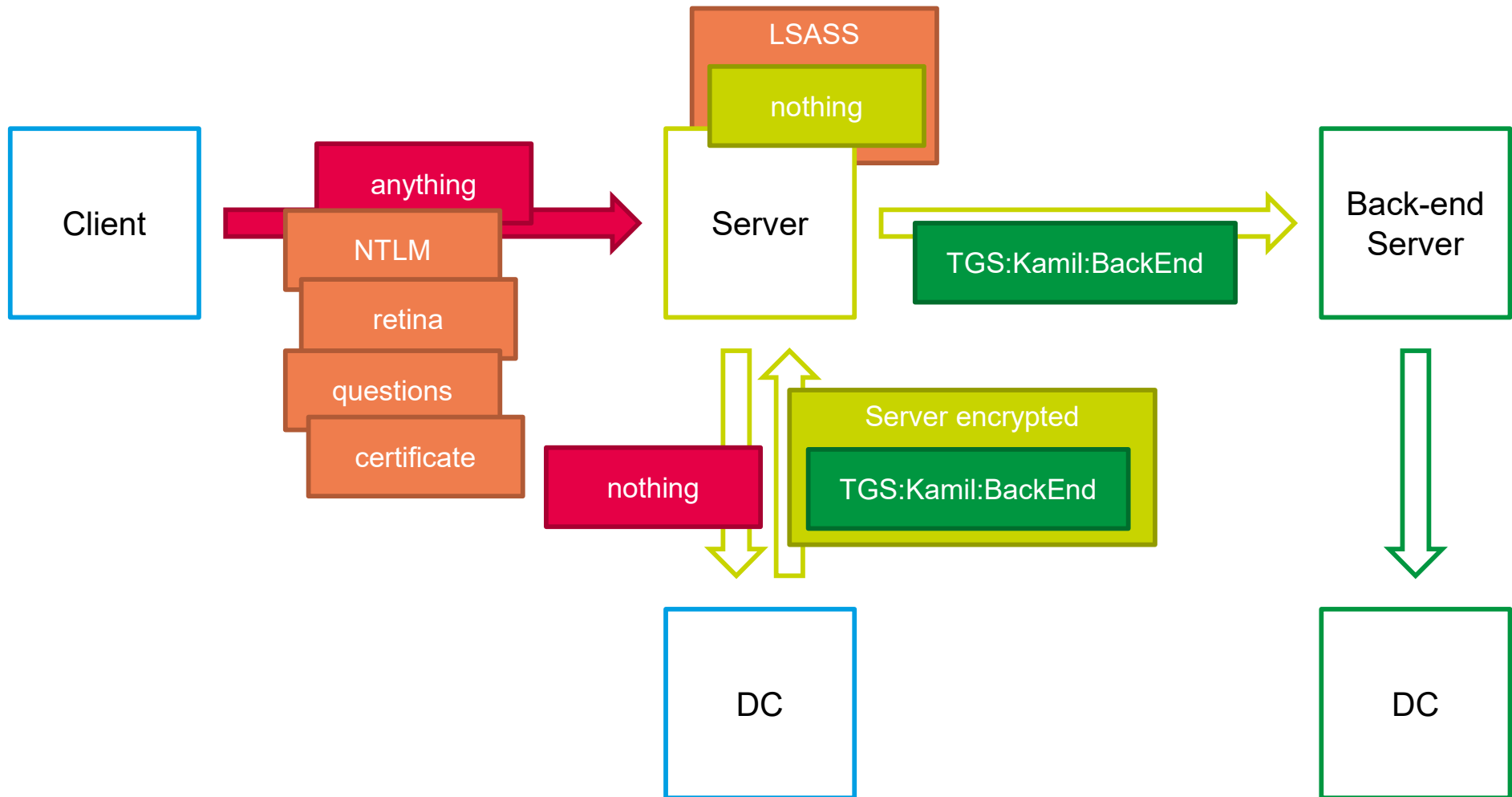
Services to which this account can present delegated credentials:

Service Type	User or Computer	Port	Service Name
cifs	GPS-DATA		
http	portal		
MSSQLSvc	GPS-DATA.gopas.vi...	49717	
MSSQLSvc	GPS-DATA.gopas.vi...	INFOSYS	

Kerberos protocol transition (DFL 2003+)



Kerberos protocol transition (DFL 2003+)



Protocol transition to SMB server account

- front-end SPN on user/gmsa account
 - no domain/gmsa account
 - no domain/gmsa account + Kernel Mode + UseAppPoolCredentials
- front-end SPN on computer account
 - ok domain/gmsa account + Kernel Mode
 - ok ApplicationPoolIdentity
 - ok Network Service
 - ok SYSTEM

Protocol transition requirements

- Server must have user right **Act as part of operating system** (**SetTcbPrivilege**)
- Server must have the **Impersonate client after authentication** (**SeImpersonatePrivilege**) user right
- **C2WTS** additional requirements
 - **C2WTS** must have the **Create global objects** (**SeCreateGlobalPrivilege**) user right
 - **C2WTS** must be running under **SYSTEM** or member of local **Administrators** group
 - Server then does **not need the SeTcbPrivilege** and does **not neet** to be member of **Administrators**

Security implications of protocol transition (use any authentication protocol)

The image shows a Windows Local Security Policy window and a Kerberos Delegation Hell tool window. The Local Security Policy window displays a list of policies, with 'Act as part of the operating system' highlighted. The Kerberos Delegation Hell tool window shows configuration details for a user named kamil@gopas.cz, including authentication type, impersonation level, and a list of groups. The 'Shared Folder Path' is set to http://portal, and the 'List content' field shows a message from GOPAS a.s.

Local Security Policy

Policy	Security Setting
Access Credential Manager as a trusted caller	
Access this computer from the network	Everyone, Administrators...
Act as part of the operating system	GPS\svc-portal

Kerberos Delegation Hell | (C) Ondrej Sevecek | ondrej@sevecek.com | www.seve...

User UPN: kamil@gopas.cz
Logon ☒ Enable Tcb and Impersonate privileges before logon

Authentication Type: Unknown
Impersonation Level: Impersonation
SID: S-1-5-21-882145292-1686642350-2485660794-1105

Groups:

User Name	SID
GPS\Domain Users	S-1-5-21-882145292-1686642350-24...
Everyone	S-1-1-0
BUILTIN\Users	S-1-5-32-545
NT AUTHORITY\NETWORK	S-1-5-2
NT AUTHORITY\Authenticated Users	S-1-5-11
NT AUTHORITY\This Organization	S-1-5-15

Shared Folder Path: http://portal
HTTP or LDAP Path:
SQL Server Connection String:
Length: 109283
Content-Type: text/html; charset=utf-8
List content: GOPAS a.s. - Home You may be trying to access this site from a secured browser on the server. P

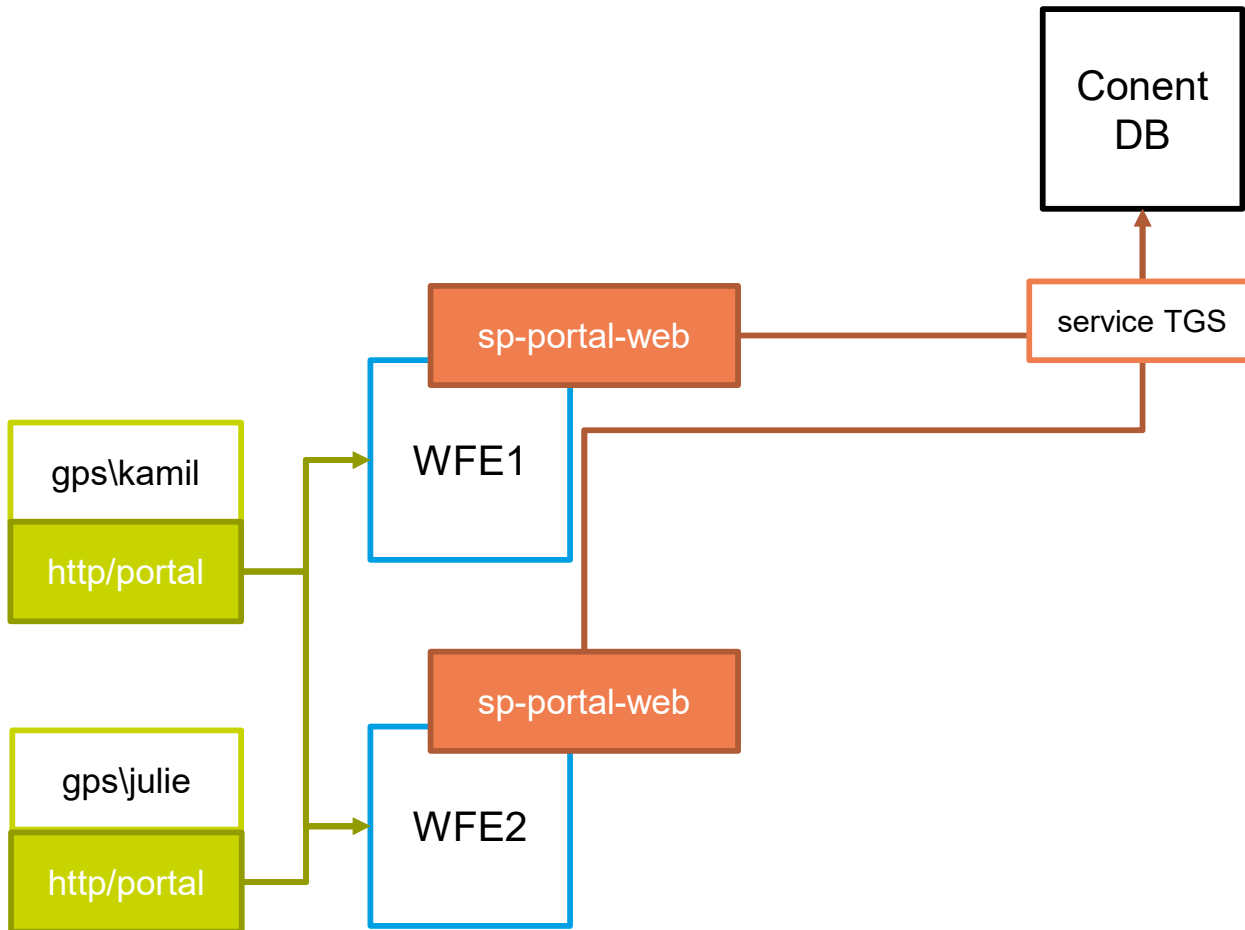
KerbHell note on access to SMB

- running under **service account** (non SYSTEM)
- SYSTEM needs to be able to delegate there as well otherwise only SQL and HTTP works

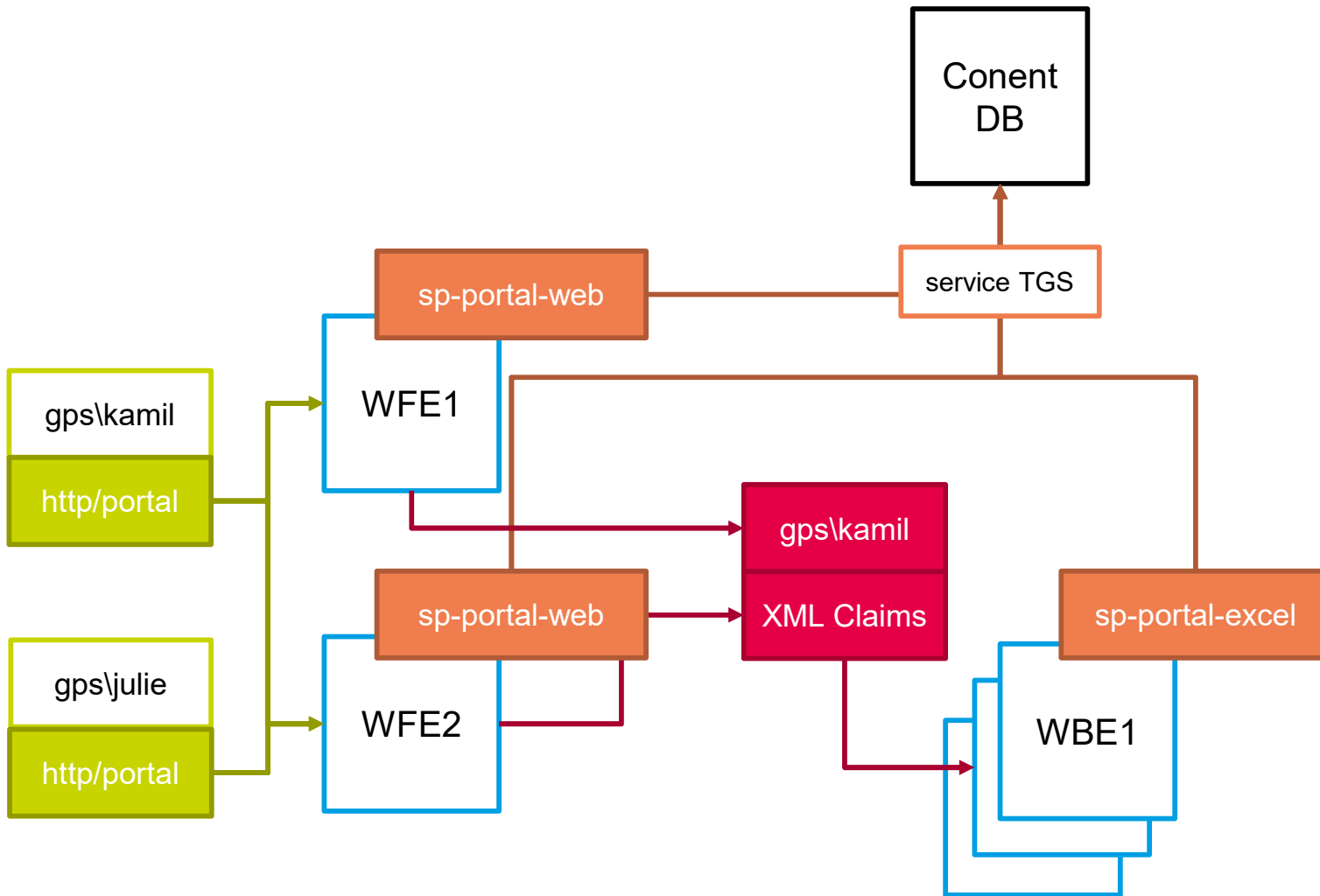
WAP access to Kerberos web servers with protocol transition

SharePoint Excel Services external data access with Kerberos constrained delegation with protocol transition

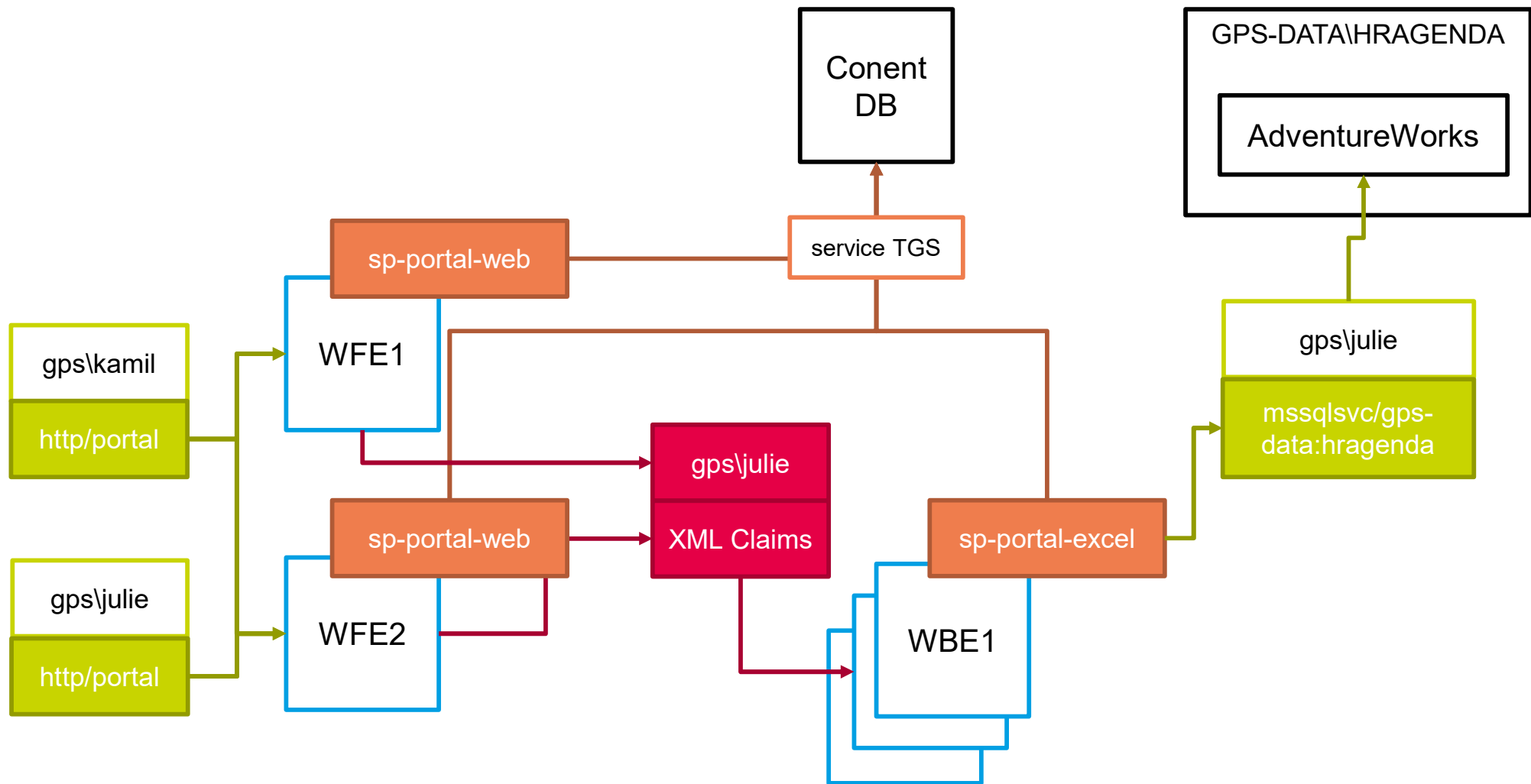
Basic SharePoint authentication infrastructure



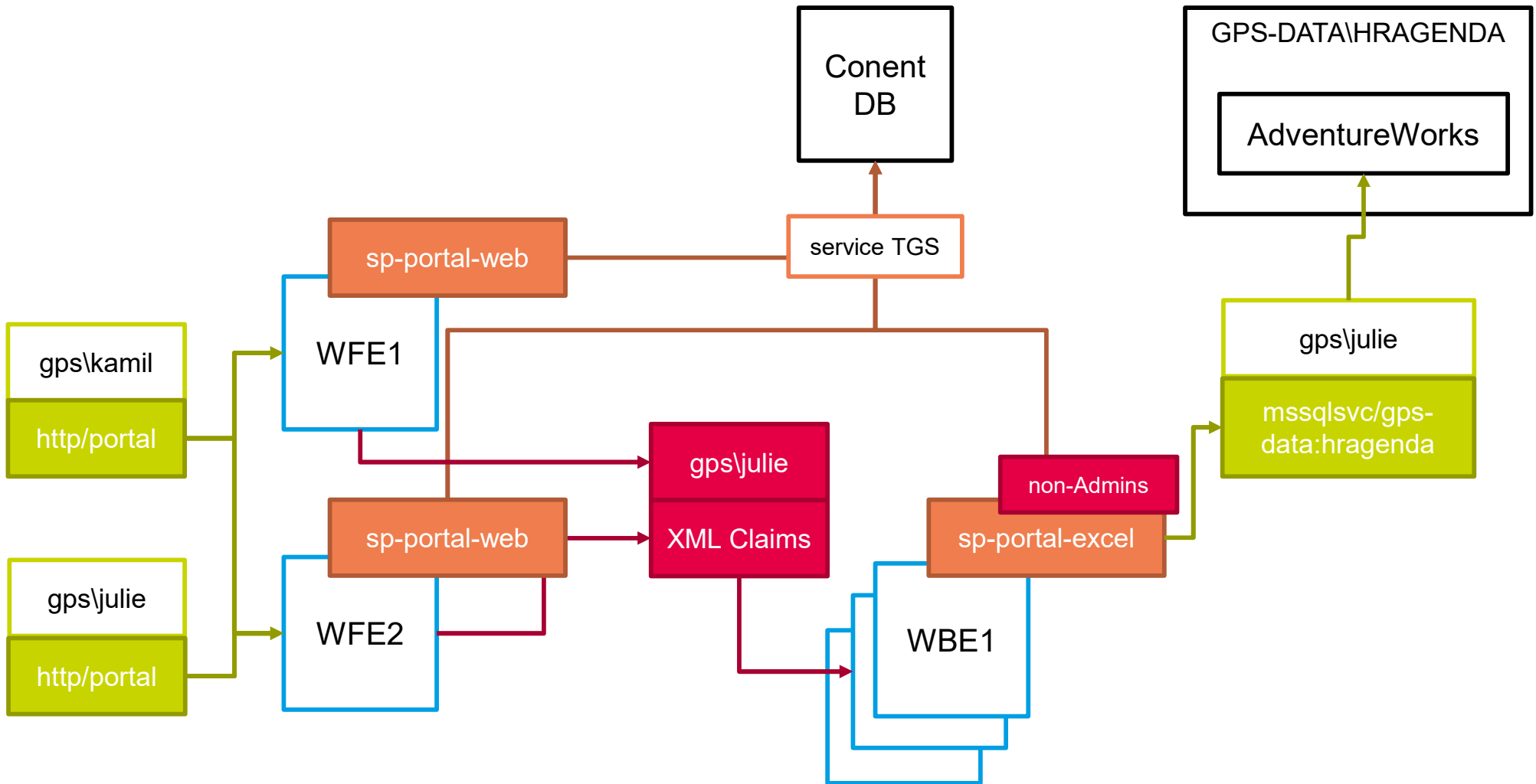
Excel services without external data access



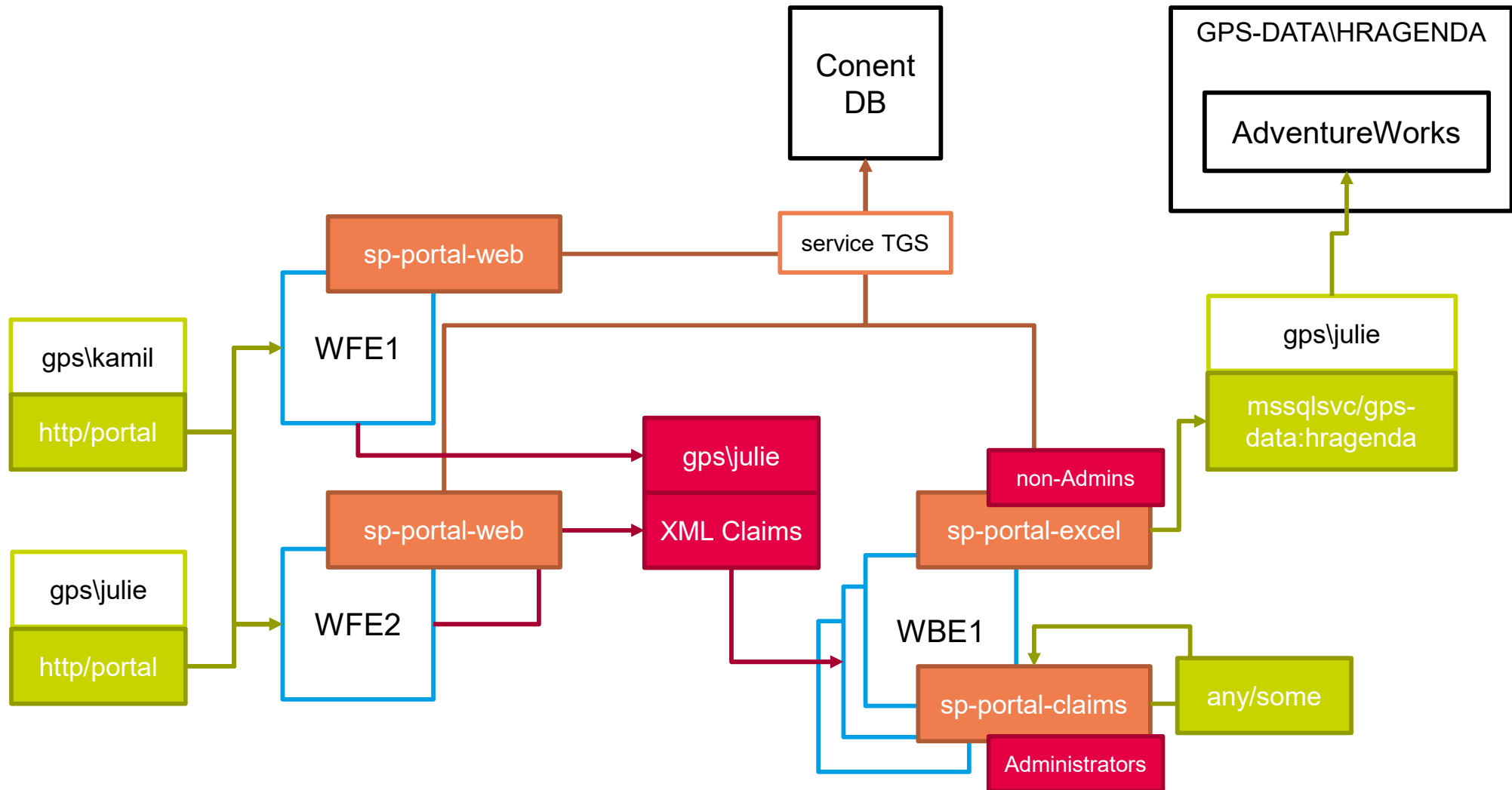
Requested Kerberos protocol transition



Requested Kerberos protocol transition



Excel Services web service must not be member of Administrators we need Claims to Windows token service (C2WTS)



Claims to Windows Token Service (C2WTS) - service account

- dummy SPN

The screenshot shows the 'sp-portal-claims Properties' dialog box. The 'Attribute Editor' tab is active, displaying a list of attributes on the left and a 'Multi-valued String Editor' on the right.

Attributes:

Attribute
sAMAccountName
sAMAccountType
scriptPath
secretary
securityIdentifier
seeAlso
serialNumber
servicePrincipalName
sevecekPasswordA
sevecekPasswordA
sevecekPasswordA
sevecek-VMB-Acc
shadowExpire

Multi-valued String Editor

Attribute: servicePrincipalName

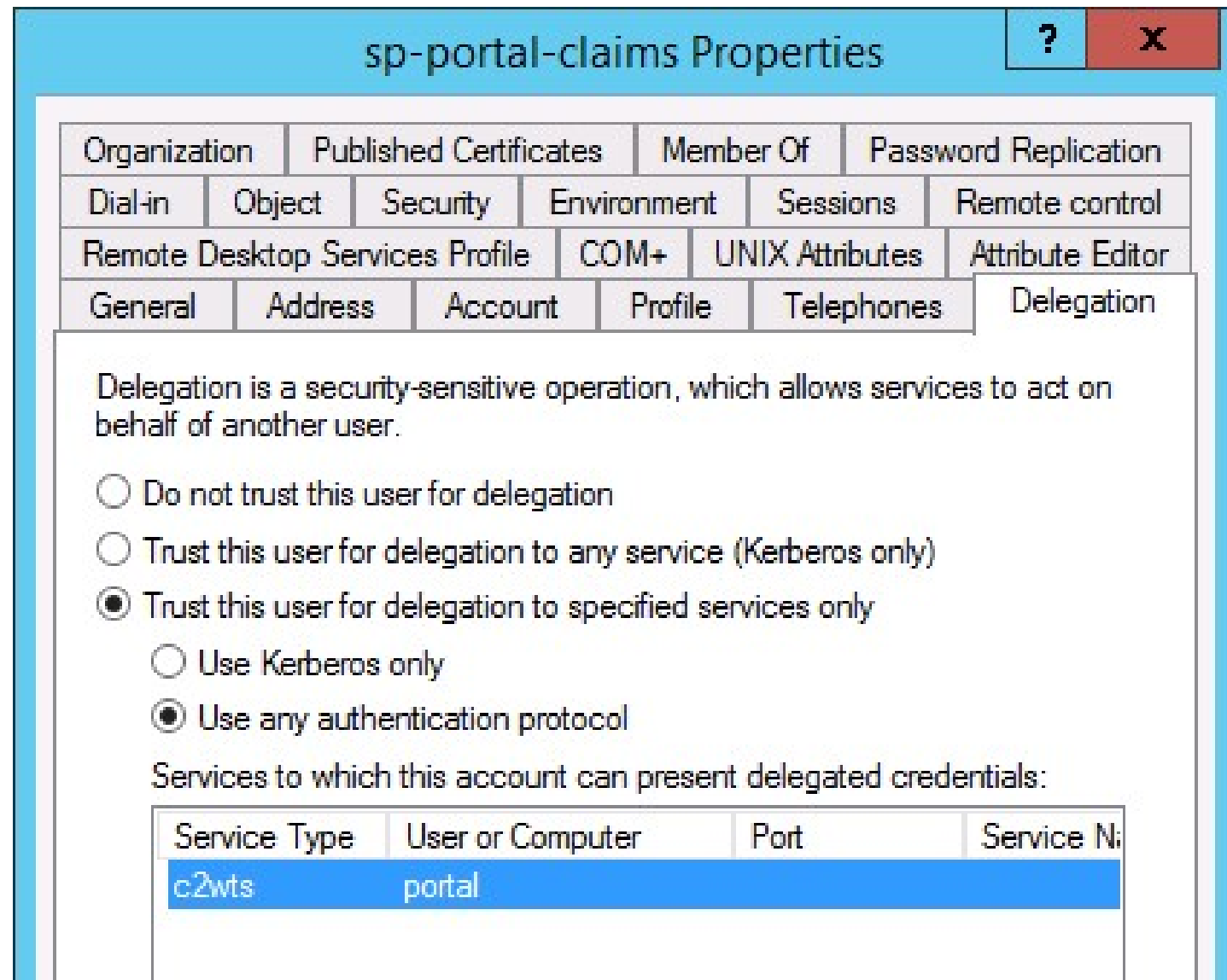
Value to add:

Values:

- c2wts/portal
- c2wts/portal.gopas.virtual

Claims to Windows Token Service (C2WTS) - service account

- Protocol transition to **itself** only



The screenshot shows the 'sp-portal-claims Properties' dialog box with the 'Delegation' tab selected. The dialog has a title bar with a question mark and a close button. Below the title bar is a tabbed interface with the following tabs: Organization, Published Certificates, Member Of, Password Replication, Dial-in, Object, Security, Environment, Sessions, Remote control, Remote Desktop Services Profile, COM+, UNIX Attributes, Attribute Editor, General, Address, Account, Profile, Telephones, and Delegation. The 'Delegation' tab is active, showing a text box with the description: 'Delegation is a security-sensitive operation, which allows services to act on behalf of another user.' Below this are four radio button options: 'Do not trust this user for delegation', 'Trust this user for delegation to any service (Kerberos only)', 'Trust this user for delegation to specified services only' (which is selected), and 'Use any authentication protocol'. Under the selected option, there is a text box labeled 'Services to which this account can present delegated credentials:' containing a table with one row: 'c2wts' in the 'Service Type' column and 'portal' in the 'User or Computer' column. The 'Port' and 'Service Name' columns are empty.

Service Type	User or Computer	Port	Service Name
c2wts	portal		

Excel Services, Performance Point Services, Reporting Services - service account

- Dummy SPN

The screenshot shows the 'sp-portal-excel Properties' dialog box. The 'Attribute Editor' tab is active, displaying a list of attributes on the left and a 'Multi-valued String Editor' on the right.

Attributes:

Attribute
sAMAccountName
sAMAccountType
scriptPath
secretary
securityIdentifier
seeAlso
serialNumber
servicePrincipalName
sevecekPasswordAn...
sevecekPasswordAn...

Multi-valued String Editor

Attribute: servicePrincipalName

Value to add:

Values:

excel/portal
excel/portal.gopas.virtual

Excel Services, Performance Point Services, Reporting Services - service account

- Protocol transition to data sources

sp-portal-excel Properties

Organization	Published Certificates	Member Of	Password Replication
Dial-in	Object	Security	Environment
Sessions	Remote control	Remote Desktop Services Profile	COM+
UNIX Attributes	Attribute Editor	General	Address
Account	Profile	Telephones	Delegation

Delegation is a security-sensitive operation, which allows services to act on behalf of another user.

☐ Do not trust this user for delegation

☐ Trust this user for delegation to any service (Kerberos only)

☒ Trust this user for delegation to specified services only

☐ Use Kerberos only

☒ Use any authentication protocol

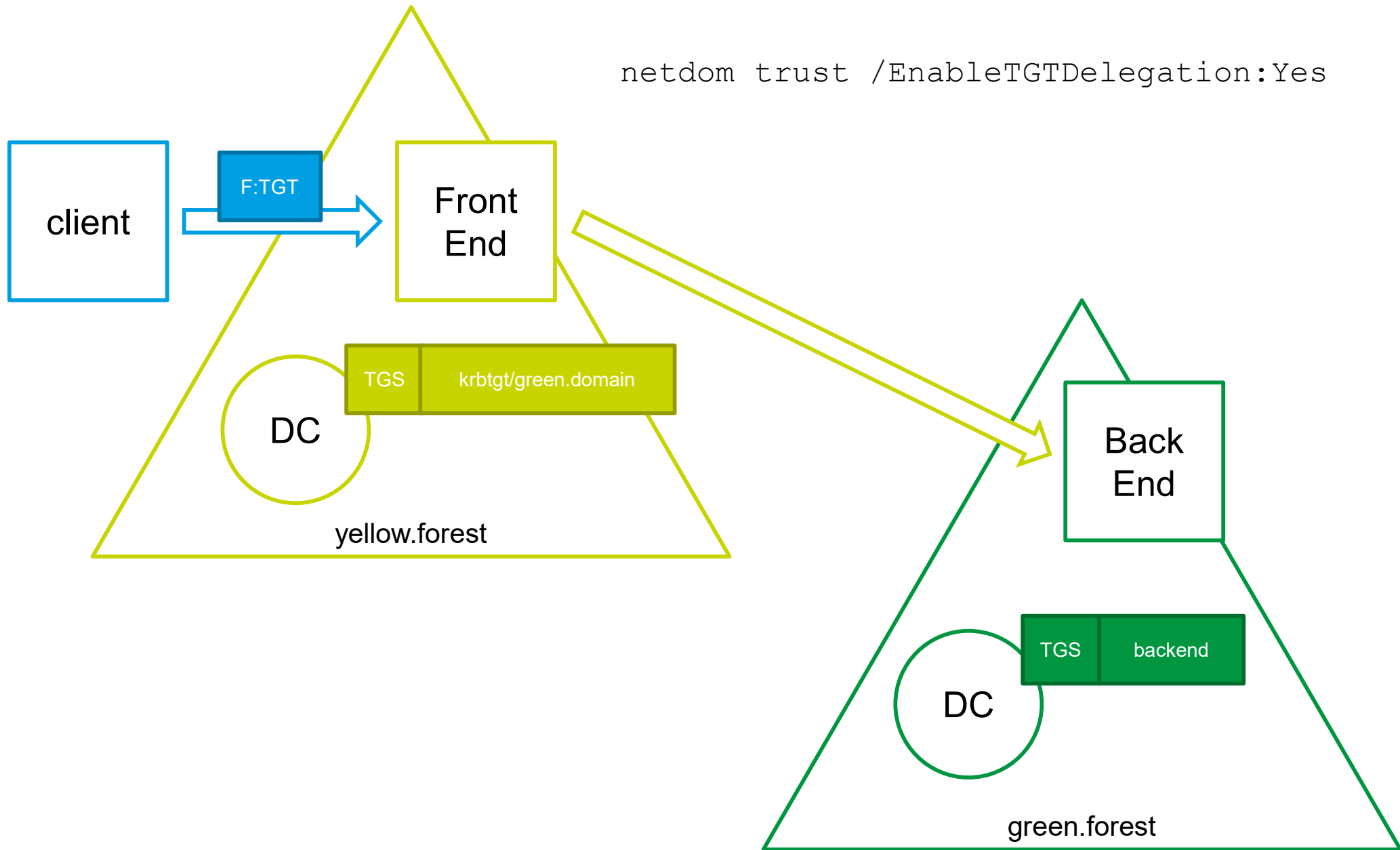
Services to which this account can present delegated credentials:

Service Type	User or Computer	Port	Domain
MSSQLSvc	GPS-DATA.gopas.virtual	49364	
MSSQLSvc	GPS-DATA.gopas.virtual	INFOSYS	

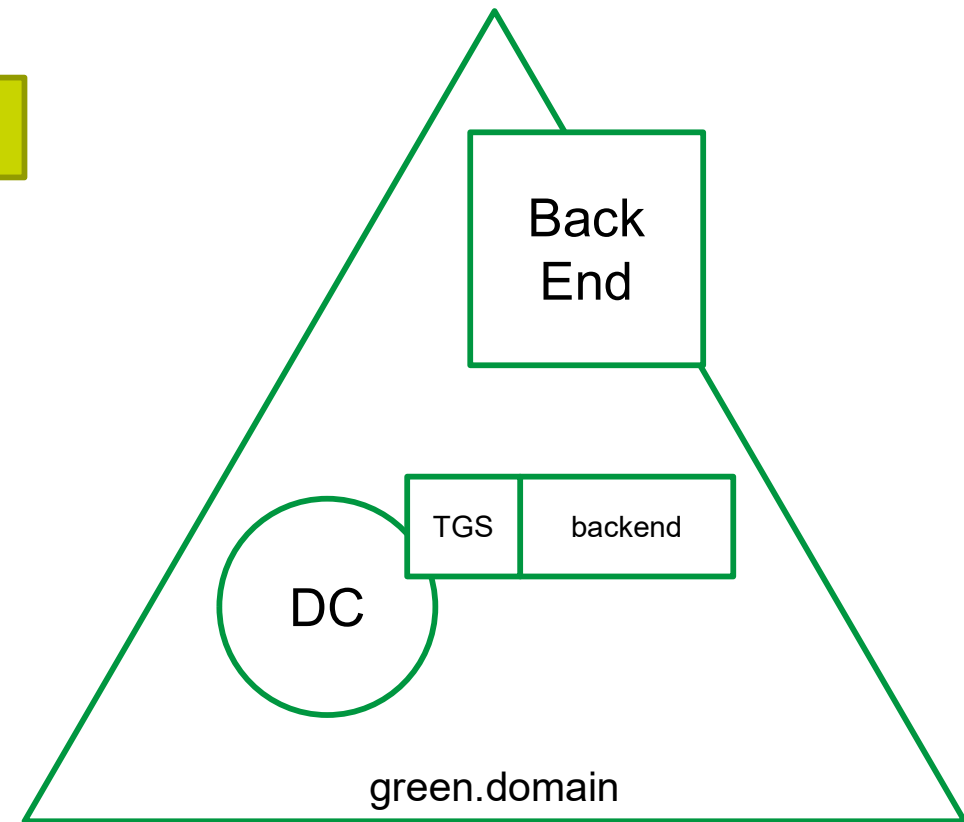
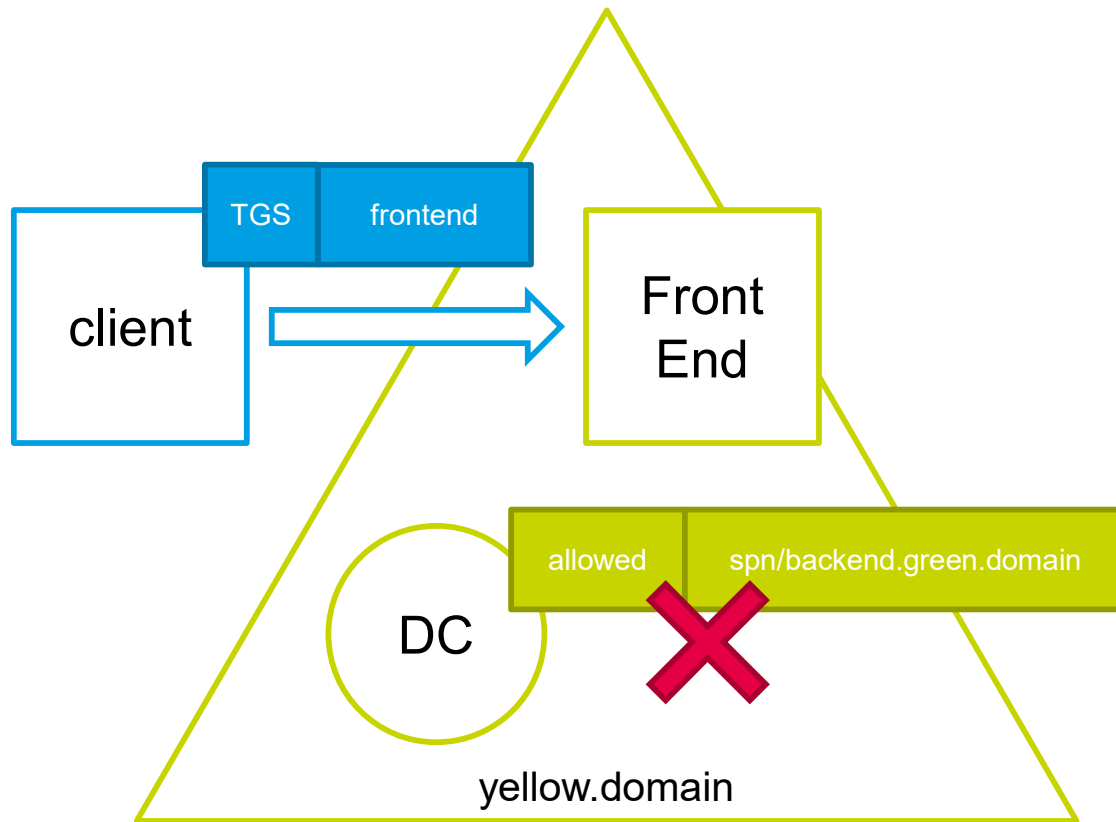
Cross-domain Kerberos delegation

Unconstrained delegation works even cross-forest (if enabled on trusts)

```
netdom trust /EnableTGTDlegation:Yes
```



Constrained delegation does not work to other domains



Protocol transition works since 2012+ (aka Resource Based Kerberos Delegation) in a single forest

